SPT-TXN
FRAMEWORK

Sovereign Policy Tokens • TBAC Capability Enforcement • ZK Privacy
Biometric Uniqueness • Transaction Chain Integrity • Multi-Chain Deployment

R.J. Coetzee
CISSP • ISSAP • ISSMP • CSSLP
BSc Computer Science
Violet Sky Security LLC • (US)
Violet Sky Security SEZC • (Cayman Islands)
Working Paper v6.0 • 02 March 2026

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Abstract

The SPT-Txn Framework v6.0 integrates Attribute-Based Access Control (ABAC), Token-Based Access Control (TBAC), Non-Fungible Tokens (NFTs), Self-Sovereign Identity (SSI), Zero-Knowledge Decentralized Identifiers (zkDID), biometric uniqueness proofs, and IETF Transaction Tokens into a unified authorization architecture for the agentic economy.

It addresses five requirements unmet by existing systems:

1. Regulatory compliance with privacy preservation
2. Portable identity without PII disclosure
3. Cryptographically enforced capability scoping and delegation depth for AI agents and microservices
4. Cross-organizational chain-of-custody integrity
5. Sybil-resistant human-in-the-loop authorization anchors

Deployment targets include EVM-compatible chains (primary), XDC Network (RWA and trade finance), Cardano/Midnight (ZK-native privacy), and Substrate parachains (enterprise sovereign). The framework enables portable compliance proofs that substantially reduce KYC onboarding costs and provide regulators with immutable audit trails.

Key Contributions

1. The two-phase evaluation model: ABAC evaluates attributes once at issuance; TBAC enforces capabilities at every access point without re-evaluation, offline-enforcement.
2. Eight-step TBAC Enforcement Engine operating solely on the Capability Token (CT), formally specified enforcement sequence operating solely on the CT, no policy engine consulted at access time.
3. Cryptographic delegation depth with scope subset invariants and immutable humanAnchor propagation, enforced across agentic hierarchies, eliminating confused deputy attacks.
4. ZK Circuit Architecture (Specification Level): formal proof statements, input/output tables, and proof system rationale for attribute proofs, compliance claims, and biometric commitments.
5. Biometric Enrollment Contract Architecture: on-chain/off-chain security boundary, nullifier registry design, and liveness attestation verification flow.
6. SPT-Txn: IETF Transaction Token extension with capability binding, ZK privacy, agentic delegation depth, and cross-organizational trust.
7. Multi-chain deployment: EVM (primary), XDC (RWA/financial services), Cardano/Midnight (ZK-native privacy), Substrate (enterprise sovereign).
8. Policy NFTs as composable, jurisdictionally-aware compliance objects enabling programmable multi-jurisdictional regulatory satisfaction.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

1. Introduction

1.1 The Authorization Gap in the Agentic Economy

Three converging trends are creating an authorization infrastructure crisis. First, the tokenization of real-world assets and proliferation of regulated protocols requires verified, compliance-provable identity at machine speed and global scale. Second, AI agents are beginning to act autonomously on behalf of humans in financial, legal, and operational contexts requiring scoped, auditable, revocable authorization that existing systems cannot provide. Third, microservice architectures have fragmented the trust perimeter such that identity propagation across service boundaries is inconsistent, privacy-destroying, and vulnerable to confused deputy attacks.

The authorization question each trend generates is identical: who authorized this action, to what scope, through what delegation chain, and can you prove it cryptographically without revealing unnecessary identity information? No existing system answers all parts of this question simultaneously.

1.2 Failure Modes of Current Approaches

System	Strengths	Critical Failures
ABAC / XACML	Fine-grained policy evaluation	Centralized Policy Decision Point (PDP) re-evaluated at every access event; no offline capability; no delegation depth model; no chain-of-custody
OAuth 2.0	Widely deployed	No attribute provenance; no ZK privacy; no agentic delegation depth; no cross-org audit trail
OpenID Connect (OIDC)	Widely deployed SSO & identity layer on top of OAuth 2.0 User authentication + ID Tokens with claims Standardized discovery & consent flows Supports some selective disclosure via scopes	Inherits all core OAuth 2.0 limitations No native ZK privacy (ID Tokens usually plaintext or lightly encrypted) No cryptographically-enforced delegation depth or scope reduction invariants No attribute provenance beyond IdP assertion No chain-of-custody or cross-org immutable audit trail No Sybil resistance or biometric anchoring No native support for agentic scoped delegation or offline-capable TBAC enforcement Token exchange (RFC 8693) delegation is weak and lacks formal invariants.
IETF Txn-Tokens	Call chain integrity in microservices	No capability scoping per hop; plaintext identity propagation; single-org assumption; no compliance claims
W3C Verifiable Credentials	User-sovereign selective disclosure	No on-chain policy enforcement; no Sybil resistance; no TBAC delegation model
Soulbound Tokens	Non-transferable on-chain identity	No ABAC policy layer; no ZK proofs; no capability scoping; no compliance claims
Worldcoin	Biometric Sybil resistance at scale	Centralized hardware/DB; no ABAC; no regulatory composability; governance risk
Polygon ID	ZK identity on EVM	No biometric uniqueness; no TBAC delegation; no Txn-Token integration; no cross-org trust

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

1.3 The SPT-Txn Approach

The SPT-Txn Framework resolves these failures through layered architectural composition. Each layer handles precisely what it is best suited for and the layers compose without conflict. ABAC evaluates attributes and computes authorization, once. TBAC enforces that pre-computed authorization at every subsequent access event, offline, at millisecond latency, without consulting the policy engine. ZK proofs ensure no PII travels with credentials or compliance claims. Biometric commitments anchor every identity to a unique human without storing biometric data anywhere. Txn-Tokens carry immutable chain-of-custody through every delegation hop.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

2. Architectural Overview

2.1 The Five-Layer Stack

```
┌──────────────────────────────────────────────────────────────────────┐
│  LAYER 5: GOVERNANCE                                                 │
│  Trust Registries (on-chain) • Policy NFT governance                 │
│  Issuer authorization • Revocation authorities                       │
└──────────────────────────────────────────────────────────────────────┘
                                  │
                                  │ ZK attribute proofs
┌──────────────────────────────────────────────────────────────────────┐
│  LAYER 4: IDENTITY  (zkDID + Biometric + SSI)                        │
│  CATs • Fuzzy commitment biometric anchor • ZK attribute proofs      │
│  Nullifier registry • Liveness attestation • Unlinkable sessions     │
└──────────────────────────────────────────────────────────────────────┘
                                  │
                                  │ ZK proofs satisfy policy?
┌──────────────────────────────────────────────────────────────────────┐
│  LAYER 3: ABAC EVALUATION  (Policy NFTs + PDP)                       │
│  Attribute evaluation • Capability Token issuance                    │
│  Root Txn-Token creation • Compliance claim encoding                 │
│  ═══ ABAC/TBAC BOUNDARY ═══ Evaluation is DONE after this layer      │
└──────────────────────────────────────────────────────────────────────┘
                                  │
                                  │ CT + Txn-Token issued
┌──────────────────────────────────────────────────────────────────────┐
│  LAYER 2: TBAC + TXN-TOKEN  (Capability & Chain-of-Custody)          │
│  Scoped Capability Tokens • Eight-step enforcement engine            │
│  Scope invariants • Delegation depth • humanAnchor propagation       │
│  Txn-Token chain integrity • Offline capable • Cross-org trust       │
└──────────────────────────────────────────────────────────────────────┘
                                  │
                                  │ CT presented at resource
┌──────────────────────────────────────────────────────────────────────┐
│  LAYER 1: ENFORCEMENT  (Resources)                                   │
│  API gateways • Smart contracts • Physical access • IoT devices      │
│  AI agent scope limiters • Cross-org service endpoints               │
│  Check: sig + scope + revocation — NOTHING ELSE                      │
└──────────────────────────────────────────────────────────────────────┘
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

3. Token Primitives

3.1 Credential Attribute Tokens (CATs)

CATs are soulbound NFTs minted from Verifiable Credentials and bound to the holder's zkDID commitment. Each CAT represents a specific verified attribute. CATs are inputs to the ABAC evaluation layer — they are never used directly for access control. The attribute value is never stored on-chain; only the ZK commitment and issuer signature are anchored.

```
CAT Token Structure:
  tokenId:          uint256   on-chain identifier
  didCommitment:    bytes32   keccak256(ZK_commit(DID)) — never raw DID
  attributeType:    bytes32   keccak256('KYC_LEVEL') | keccak256('AML_STATUS')
etc.
  issuerDID:        string    published, Trust Registry-listed DID
  issuanceTime:     uint64    Unix timestamp
  expiryTime:       uint64    0 = no expiry; non-zero = hard expiry
  oracleRef:        address   0x0 = static attribute; else: oracle contract
  soulbound:        bool      if true: non-transferable (identity attrs)
  revoked:          bool      issuer-controlled revocation flag
```

3.2 Policy NFTs (PNFTs)

PNFTs are the ABAC policy layer, the most novel primitive in the framework. The access control policy itself becomes an NFT owned by the resource owner. The PNFT defines two things: the attribute requirements a subject must prove, and the capability specification that the resulting CT will encode. PNFTs are composable, multiple PNFTs can be combined for multi-jurisdictional compliance stacking.

```
PNFT Structure:
  policyId:         uint256   on-chain identifier
  version:          uint32    policies are versioned, not mutated in-place
  owner:            address   resource owner — controls policy lifecycle
  attributeRules:   Rule[]    ABAC conditions: { type, operator, value }
  capabilitySpec:   CapSpec   defines the CT that will be issued on satisfaction
  jurisdiction:     bytes32[] regulatory frameworks this policy satisfies
  composedWith:     uint256[] parent PNFT IDs (joint policy composition)
  maxCTDuration:    uint64    ceiling on issued CT lifetime
  active:           bool      policy owner can deactivate
```

3.3 Capability Tokens (CTs) — The TBAC Primitive

Capability Tokens are the ABAC evaluation result encoded as a cryptographically signed, offline-verifiable authorization object. The CT is the complete authorization state. Possessing a valid CT for a resource and action IS the authorization. No further policy evaluation is required or permitted at access time.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

```
Capability Token — Complete Structure:

  IDENTITY:
    ctId:              string    UUID — unique token identifier
    holder:            bytes32   zkDID commitment of current holder
    humanAnchor:       bytes32   zkDID commitment of root authorizing human
                                 Immutable across entire delegation chain

  CAPABILITY (the TBAC core):
    capability.resource:    string    what resource this CT covers
    capability.actions:     string[]  permitted operations
    capability.constraints: map       { maxValueUsd, maxDailyVol,
                                        allowedCounterparties, ... }

  COMPLIANCE (ZK proofs — no PII):
    complianceClaims.kycProof:          bytes    ZK proof: KYC satisfies policy
    complianceClaims.jurisdictionProof: bytes    ZK proof: jurisdiction satisfies
    complianceClaims.amlProof:          bytes    ZK proof: AML status current
    complianceClaims.oracleCommit:      bytes32  oracle Merkle root referenced
    complianceClaims.proofTimestamp:    uint64   when proofs were generated

  DELEGATION:
    delegation.maxDepth:      uint8   ceiling set at root — never changes
    delegation.currentDepth:  uint8   decrements at each delegation hop
    delegation.parentCtRef:   bytes32 hash of parent CT (null if root)
    delegation.scopeRule:     enum    MUST_REDUCE | MAY_REDUCE | FIXED
    delegation.delegatable:   bool    can this CT be further delegated?

  LIFECYCLE:
    validFrom:        uint64   Unix timestamp
    validUntil:       uint64   hard expiry
    revocationNonce:  bytes32  checked against revocation registry

  PROVENANCE:
    policyRef:        uint256  PNFT tokenId that authorized this CT
    issuerDid:        string   ABAC PDP DID
    issuerSig:        bytes    ECDSA-P256 signature over canonical CT payload
```

3.4 Delegation Tokens

Delegation Tokens are child CTs derived from a parent CT with equal or reduced scope. The delegation chain is cryptographically linked: revoking any node invalidates all descendants. Scope invariants are enforced at issuance, a child CT cannot grant more than its parent contains.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

4. Token-Based Access Control (TBAC) Layer

Token-Based Access Control (TBAC) is a fundamentally distinct authorization paradigm from ABAC. In ABAC, the policy engine is consulted on every access event. In TBAC, the policy engine ran once at issuance and its result, the Capability Token, is the complete authorization state. At every subsequent access event, only the token is evaluated. No policy engine. No attribute store. No network call required.

Dimension	ABAC	TBAC	SPT-Txn Combined
Policy evaluation	Every access event	At token issuance only	ABAC once → TBAC always
PDP at enforcement	Required every time	Never required	Never — PDP only at issuance
Offline capable	No	Yes	Yes — after CT issued
Latency at enforcement	100ms–seconds (PDP call)	<1ms (local check)	<1ms
Delegation model	Re-evaluate per delegatee	Derive scoped child CT	Cryptographic, depth-bounded
Confused deputy attack	Partially mitigated	Eliminated	Cryptographically impossible
Cross-org enforcement	Requires shared PDP	Verify signature only	Trust Registry lookup
AI agent suitability	Poor — PDP overhead	Strong — token IS scope	Native — designed for agents
Scale	Bottlenecked by PDP	Horizontal, stateless	Horizontal, stateless

From years of designing secure architectures, I've seen ABAC / PDP re-evaluation become a hidden bottleneck in high-throughput environments. Separating evaluation from enforcement once and for all is, in my view, the single most practical improvement this framework offers.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

4.1 The ABAC-to-TBAC Boundary

The ABAC-to-TBAC boundary is the most important architectural concept in the framework. It is the line between evaluation and enforcement. Everything left of the boundary involves policy, attributes, and decision-making. Everything right of the boundary involves tokens, scopes, and verification. The two domains never overlap at runtime.

```
╔═══════════════════════════════╗   ╔═══════════════════════════════╗
║         ABAC DOMAIN           ║   ║         TBAC DOMAIN           ║
║                               ║   ║                               ║
║  Subject presents ZK proofs   ║   ║  Subject presents CT          ║
║  of attributes to PDP         ║   ║  to enforcement point         ║
║         ↓                     ║   ║         ↓                    ║
║  PDP evaluates attributes     ║   ║  Check 1: Signature valid?    ║
║  against Policy NFT rules     ║   ║  Check 2: Not expired?        ║
║         ↓ satisfied           ║   ║  Check 3: Not revoked?        ║
║  PDP issues signed CT         ║   ║  Check 4: Issuer trusted?     ║
║  encoding: what, where,       ║   ║  Check 5: Resource matches?   ║
║  how much, until when, depth  ║   ║  Check 6: Action permitted?   ║
║                               ║   ║  Check 7: Constraints met?    ║
║  ═══ THIS HAPPENS ONCE ═══    ║   ║  Check 8: Depth valid?        ║
║  Policy engine is DONE.       ║   ║         ↓                    ║
║                           CT →→→→→→  PERMIT or DENY               ║
╚═══════════════════════════════╝   ║  No PDP. No attrs. No network.║
                                    ╚═══════════════════════════════╝
```

4.2 The Eight-Step TBAC Enforcement Engine

The TBAC Enforcement Engine is a standalone component entirely separate from the ABAC layer. It receives a raw Capability Token and an access request through a format-agnostic verification interface. The CT may be serialised as JWT, SD-JWT, Biscuit, or CWT depending on the deployment context (see Section 7.4 for the token format selection mapping). The engine returns PERMIT or DENY. That is its complete contract. The engine performs exactly eight checks in sequence. If any check fails, the result is immediate DENY. If all eight pass, the result is PERMIT. No exceptions, no fallbacks, no escalation to a policy engine.

Step 1 — Cryptographic Signature Verification

Verify the CT was signed by an ABAC PDP whose public key is registered in the applicable Trust Registry (for JWT/SD-JWT this is JWS verification; for Biscuit, public-key block signature verification; for CWT, COSE signature verification). An invalid signature is an immediate DENY regardless of all other fields. This step requires no external call, the PDP public key is cached locally.

Step 2 — Temporal Validity

Verify the current time is within [validFrom, validUntil]. A CT presented before its validFrom time or after its validUntil time is rejected. No grace period. No clock skew tolerance beyond a configurable epsilon (recommended: 30 seconds).

Step 3 — Revocation Registry Check

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Query the revocation registry for the CT's revocationNonce. If the nonce is present with a revocationTimestamp, the CT is revoked and the request is denied. This is the only external call in the enforcement sequence and MAY be satisfied from a locally cached registry snapshot for offline capability.

Step 4 — Issuer Trust Verification

For cross-organizational deployments, verify the CT's issuerDid is listed in the applicable Trust Registry for the requested resource type. Single-organization deployments may skip this step if the PDP public key is statically configured.

Step 5 — Resource Scope Match

Verify the CT's capability resource covers the requested resource. Exact match or wildcard match (e.g., 'trading:*' covers 'trading:equities' and 'trading:bonds'). A CT scoped to 'trading:equities' does not cover 'settlement:equities'. The boundary is the colon-separated prefix.

Step 6 — Action Permission Check

Verify the requested action is in the CT's capability.actions array. Actions are opaque string identifiers defined by the resource owner. A CT with actions ['read', 'execute'] does not permit 'delete'. Wildcard actions ('*') are permitted but discouraged, Policy NFTs should define explicit action sets.

Step 7 — Constraint Evaluation

Evaluate runtime constraints against the current request context. This is the only contextually dynamic check, all prior checks are stateless. Constraint types include: maxValueUsd (single transaction value ceiling), maxDailyVolumeUsd (daily aggregate ceiling, requires rate limiter service), allowedCounterparties (permitted counterparty identifier set), and deployment-specific extensions.

Step 8 — Delegation Depth Validation

Verify the CT's delegation.currentDepth is non-negative and consistent with the chain. A depth of zero at enforcement time does not deny access, it denies further delegation. The depth is validated for consistency with the declared maxDepth and parentCtRef chain. Negative or inconsistent depth values are an immediate DENY.

4.3 Scope Invariants — Cryptographically Enforced

The scope invariants are the formal guarantees that make the TBAC delegation model secure. They are enforced at CT issuance time by the ABAC PDP, not at enforcement time. An issuance service that violates any invariant MUST reject the delegation request.

In my experience securing distributed systems under strict compliance regimes, these invariants are non-negotiable-any relaxation invites privilege escalation that auditors will flag immediately.

```
INVARIANT 1: Resource Subset
  capability(child).resource == capability(parent).resource
  OR capability(child).resource is a strict sub-resource
  of capability(parent).resource
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

```
INVARIANT 2: Action Subset
  capability(child).actions ⊆ capability(parent).actions
  Every action in the child MUST exist in the parent.

INVARIANT 3: Constraint Tightening
  For every numeric constraint c:
    child.constraints[c] ≤ parent.constraints[c]
  For every set constraint c:
    child.constraints[c] ⊆ parent.constraints[c]
  Child constraints MUST be equal or more restrictive than parent.

INVARIANT 4: Depth Decrement
  child.delegation.currentDepth = parent.delegation.currentDepth - 1

INVARIANT 5: Max Depth Preservation
  child.delegation.maxDepth = parent.delegation.maxDepth
  The ceiling set at the root never changes.

INVARIANT 6: Human Anchor Preservation
  child.humanAnchor = parent.humanAnchor = root.humanAnchor
  The authorizing human's zkDID commitment propagates unchanged.

INVARIANT 7: Depth Floor Enforcement
  IF parent.delegation.currentDepth == 0:
    Delegation MUST be rejected.
    Error: 'spt_delegation_depth_exceeded'

Violation of any invariant: delegation CT issuance MUST be rejected.
```

4.4 Object-Capability Security and the Confused Deputy Problem

The TBAC CT primitive implements object-capability security, a security model whose formal foundations trace to Hardy (1988) and Miller (2006). In the object-capability model, authorization is a first-class object that can be held, used, and transferred, but cannot be forged or amplified. Possessing a valid capability is both sufficient and necessary for authorization.

The CT implements this precisely: **possessing a valid CT permits exactly the action it describes, nothing more.** The enforcement point checks only the CT, not the caller's ambient authority, role, or system position. A compromised intermediate service holding a CT scoped to 'read:pricing' cannot use its position in a high-privilege transaction chain to execute a trade. The scope is the authority. The authority cannot be exceeded. This is the formal elimination of the confused deputy attack.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

5. ZK Circuit Architecture

The ZK proof layer provides the privacy properties that make SPT-Txn qualitatively different from existing authorization frameworks. This section specifies the ZK circuits at formal proof statement level, sufficient for cryptographic review and implementation guidance, without full circuit code.

5.1 Proof System Selection

Proof System	Setup	Proof Size	Verify Time	EVM Cost	Rationale
Groth16	Trusted per-circuit	~192 bytes	<1ms	~250K gas	Smallest proofs, cheapest on-chain verification. Required: per-circuit trusted setup ceremony.
PLONK / UltraPlonk	Universal SRS	~500 bytes	~2ms	~400K gas	Universal setup — one ceremony for all circuits. Noir compiles to UltraPlonk by default.
STARKs	None (transparent)	~50KB	~5ms	High	No trusted setup. Proof size too large for on-chain verification at current gas costs.
Noir / Barretenberg	Universal SRS	~500 bytes	~2ms	~400K gas	Selected. Best developer experience. EVM verifier generated automatically. TypeScript prover.

Selected: Noir (Aztec) with Barretenberg backend. Rationale: universal SRS eliminates per-circuit trusted setup ceremonies; auto-generated Solidity verifier contracts deploy directly on EVM chains; TypeScript prover integrates natively with the NestJS backend; active development and audit history from Aztec. For Cardano/Midnight deployments, Midnight's native ZK runtime replaces Noir, the proof statements are identical; only the prover backend changes.

5.2 Circuit 1 — Attribute Proof Circuit

Purpose

Proves that a subject holds a valid Credential Attribute Token from a Trust Registry-listed issuer, and that the attribute value satisfies a policy condition, without revealing the attribute value, the DID, or the CAT tokenId.

Formal Proof Statement

```
PROVE:
  I know (attribute_value, did_secret, issuer_sig) such that:
    (a) did_commitment   = Pedersen(did_secret)
    (b) attr_commitment  = Pedersen(did_commitment || attribute_value)
    (c) Verify(issuer_pk, issuer_sig, attr_commitment) = TRUE
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

```
    (d) issuer_pk ∈ Trust_Registry_Merkle_Tree
    (e) EvalOperator(operator, attribute_value, comparison_value) = TRUE

WITHOUT REVEALING:
  attribute_value, did_secret, issuer_sig, issuer_pk
```

Input / Output Table

Input	Type	Public / Private	Description
attribute_value	Field	PRIVATE	The actual attribute value (e.g. KYC level integer)
did_secret	Field	PRIVATE	DID pre-image — never leaves the prover
issuer_sig	[Field;2]	PRIVATE	Issuer's ECDSA signature over attr_commitment
issuer_pk	[Field;2]	PRIVATE	Issuer public key — verified against Trust Registry
did_commitment	Field	PUBLIC	Pedersen(did_secret) — the zkDID commitment
comparison_value	Field	PUBLIC	The threshold value the attribute is compared against
operator	u8	PUBLIC	0=EQ, 1=GTE, 2=LTE, 3=IN, 4=RANGE
trust_registry_root	Field	PUBLIC	Merkle root of authorized issuer public keys
issuer_merkle_path	[Field;N]	PRIVATE	Merkle inclusion proof for issuer_pk

Constraint Count Estimate

```
  Pedersen hash (x2):          ~4,000 constraints
  ECDSA signature verification: ~30,000 constraints
  Merkle inclusion proof:       ~2,000 constraints (depth 20)
  Operator evaluation:          ~500 constraints
  Total:                        ~36,500 constraints

  Proof generation time (client device): ~800ms
  Proof verification time (server):      <2ms
  On-chain verification cost (EVM):      ~380,000 gas
```

5.3 Circuit 2 — Compliance Claim Circuit

Purpose

Proves that a subject's KYC level, AML status, and jurisdiction satisfy the compliance requirements encoded in a Policy NFT, against an oracle-committed attribute state, without revealing attribute values or identity.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Formal Proof Statement

```
PROVE:
  I know (kyc_level, aml_score, jurisdiction, did_secret,
          oracle_sig, merkle_path) such that:
    (a) did_commitment = Pedersen(did_secret)
    (b) The tuple (did_commitment, kyc_level, aml_score, jurisdiction)
        is a leaf in the Oracle Merkle Tree with root oracle_commit
    (c) Verify(oracle_pk, oracle_sig, oracle_commit) = TRUE
    (d) kyc_level >= policy.min_kyc_level
    (e) aml_score <= policy.max_aml_score
    (f) jurisdiction ∈ policy.allowed_jurisdictions

WITHOUT REVEALING:
  kyc_level, aml_score, jurisdiction, did_secret, merkle_path
```

Input / Output Table

Input	Type	Public / Private	Description
kyc_level	u8	PRIVATE	Integer KYC level (e.g. 1-5)
aml_score	u32	PRIVATE	AML risk score
jurisdiction	Field	PRIVATE	Jurisdiction identifier (hashed)
did_secret	Field	PRIVATE	DID pre-image
merkle_path	[Field;N]	PRIVATE	Oracle Merkle inclusion proof
oracle_sig	[Field;2]	PRIVATE	Oracle signature over oracle_commit
did_commitment	Field	PUBLIC	zkDID commitment — links to CAT
oracle_commit	Field	PUBLIC	Oracle Merkle root (on-chain, timestamped)
policy_min_kyc	u8	PUBLIC	Minimum KYC level from Policy NFT
policy_max_aml	u32	PUBLIC	Maximum AML score from Policy NFT
policy_jurisdictions	Field	PUBLIC	Hash of allowed jurisdiction set

5.4 Circuit 3 — Biometric Commitment Circuit

Purpose

Proves that a biometric sample recovers the same secret R used to generate the on-chain commitment, demonstrating continuity of biometric identity, without revealing R, the raw biometric template, or any derivable biometric data.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Formal Proof Statement

```
PROVE:
  I know (R, nonce) such that:
    (a) commitment = Hash(R || nonce)
    (b) commitment matches the on-chain enrollment commitment C
    (c) Liveness attestation A is valid over (R, liveness_challenge)
        signed by hardware root of trust key H_pk

WHERE:
  R is recovered via: FuzzyExtractor.Rep(biometric_sample, helper_data)
  The biometric sample never leaves the secure enclave.
  R is zeroed from memory after the proof is generated.

WITHOUT REVEALING:
  R, biometric_sample, nonce, helper_data
```

Input / Output Table

Input	Type	Public / Private	Description
R	bytes32	PRIVATE	Fuzzy extractor secret — recovered from biometric
nonce	bytes32	PRIVATE	Enrollment nonce — prevents pre-image attacks
liveness_sig	bytes	PRIVATE	Hardware attestation signature over R + challenge
commitment	bytes32	PUBLIC	On-chain enrollment commitment C = Hash(R||nonce)
liveness_challenge	bytes32	PUBLIC	Fresh challenge issued by verifier
hardware_pk	[Field;2]	PUBLIC	Secure enclave root of trust public key
nullifier	bytes32	PUBLIC	PRF(R, domain) — for nullifier registry check

5.5 Blind Oracle Query Protocol

Compliance claims reference an oracle-committed attribute state. The oracle publishes a Merkle root over all {DID_i, attribute_i} tuples at a given timestamp. The subject proves their attributes are in the Merkle tree and satisfy the policy conditions without the oracle learning who queried.

```
Oracle publishes:  Merkle root M over {(DID_i, attrs_i)} at time T
Subject generates: ZK proof over M using Circuit 2 (above)
Verifier checks:   ZK proof validity against M

Oracle learns:     Nothing about who queried or when
Verifier learns:   Attributes satisfy policy as of timestamp T
Subject reveals:   ZK proof only — no attribute values, no DID
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

6. Biometric Enrollment Contract Architecture

The biometric layer provides Sybil resistance, the guarantee that each physical human can enroll exactly once, without storing biometric data anywhere. This section specifies the on-chain/off-chain security boundary, the smart contract architecture, and the enrollment and authentication flows.

6.1 Security Boundary — What Lives Where

Component	Location	Rationale
Raw biometric sample	Secure enclave only — never leaves device	Biometric data cannot be revoked if compromised. Must never leave hardware boundary.
Fuzzy extractor secret R	Zeroed after commitment generation	R enables biometric recovery. Storing it defeats the commitment scheme.
Helper data P	Device storage (public — safe to store)	P enables biometric recovery of R from future samples but reveals nothing without the biometric itself.
Enrollment commitment C	On-chain (NullifierRegistry contract)	Public commitment enables ZK proof verification without revealing R or the biometric.
Nullifier N	On-chain (NullifierRegistry contract)	Prevents same biometric from enrolling twice. PRF(R, domain) — one-way from R.
Liveness attestation	Signed by secure enclave — verified on-chain	Proves biometric was captured from a live person on certified hardware.
ZK proof of commitment	Generated in enclave, transmitted to verifier	Proves R is known without revealing R. Short-lived — not stored.

6.2 On-Chain Contract Architecture

NullifierRegistry Contract

The NullifierRegistry is an append-only, singleton contract that enforces global biometric uniqueness. It stores PRF-derived nullifiers, one per enrolled human. The nullifier is computationally one-way from the biometric and reveals nothing about the biometric or the DID.

```
NullifierRegistry Contract Interface:

  enroll(
    nullifier:   bytes32,  // PRF(R, domain_separator)
    commitment:  bytes32,  // Hash(R || nonce) — on-chain anchor
    attestation: bytes,    // liveness attestation from secure enclave
    zkProof:     bytes     // Circuit 3 proof — proves commitment valid
  ) returns (bool)
  // Checks: nullifier not present + zkProof valid + attestation valid
  // If all pass: append nullifier + commitment to registry
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

```
  // Emit: Enrolled(commitment, block.timestamp)

  isEnrolled(nullifier: bytes32) returns (bool)
  // Read-only. Used before enrollment to check for duplicates.

  getCommitment(nullifier: bytes32) returns (bytes32)
  // Returns commitment for a known nullifier.
  // Used for ZK proof verification — verifier checks proof against commitment.

  revokeCommitment(
    nullifier:  bytes32,
    revokerSig: bytes   // governance authority or court order signature
  )
  // Marks commitment as revoked. Nullifier slot is NOT freed.
  // The physical person cannot re-enroll without governance approval.
  // This is by design — biometric slots are permanent.
```

Enrollment Flow — Step by Step

```
STEP 1: Liveness Challenge (server-side)
  Verifier issues fresh liveness_challenge (random bytes32)
  Transmitted to user's device

STEP 2: Biometric Capture + Fuzzy Extractor (secure enclave only)
  User presents biometric to device sensor
  Device verifies liveness (depth sensor, IR, challenge-response)
  Secure enclave executes:
    biometric_template = capture()
    (R, helper_data) = FuzzyExtractor.Gen(biometric_template)
    nonce = SecureRandom.bytes32()
    commitment = Hash(R || nonce)
    nullifier = PRF(R, DOMAIN_SEPARATOR)
    liveness_sig = Enclave.sign(R || liveness_challenge)
    // R is used for ZK proof generation below, then ZEROED

STEP 3: ZK Proof Generation (secure enclave)
  Generate Circuit 3 proof:
    private inputs: R, nonce, liveness_sig
    public inputs:  commitment, liveness_challenge,
                    hardware_pk, nullifier
  R is ZEROED from enclave memory after proof generation

STEP 4: Nullifier Check (client → chain)
  Query NullifierRegistry.isEnrolled(nullifier)
  If TRUE: enrollment rejected — biometric already enrolled
  If FALSE: proceed

STEP 5: Enrollment Transaction (client → chain)
  Call NullifierRegistry.enroll(
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

```
    nullifier, commitment, liveness_sig, zkProof
  )
  Contract verifies: zkProof valid + liveness_sig valid + nullifier absent
  Contract appends: nullifier → commitment mapping

STEP 6: CAT Minting
  On successful enrollment: mint biometric CAT to zkDID commitment
  CAT.attributeType = keccak256('BIOMETRIC_ENROLLED')
  CAT.didCommitment = keccak256(ZK_commit(DID))
  CAT is soulbound — non-transferable by design
```

Authentication Flow — Step by Step

```
STEP 1: Fresh biometric sample captured in secure enclave
  (R, helper_data) previously stored on device after enrollment

STEP 2: Fuzzy extractor recovery
  R' = FuzzyExtractor.Rep(new_biometric_sample, helper_data)
  If biometric matches: R' == R (within fuzzy tolerance)
  If no match: R' ≠ R → ZK proof generation fails naturally

STEP 3: ZK proof generation
  Generate Circuit 3 proof with R' as the secret input
  Public input: on-chain commitment C
  Proof verifies: Hash(R' || nonce) == C
  If R' ≠ R: proof is invalid — verification fails

STEP 4: Proof submission to ABAC PDP
  PDP verifies proof against on-chain commitment
  PDP learns: SAME PERSON as enrolled / NOT SAME PERSON
  PDP proceeds with CT issuance if proof valid
```

6.3 Recovery and Revocation Policy

Biometric data cannot be revoked or reissued like passwords. The framework's approach is explicit: there is no recovery path for a compromised biometric commitment. The nullifier slot is permanent. This is intentional, biometric Sybil resistance requires that physical uniqueness is a permanent invariant of the system.

For exceptional cases (device compromise, coercion, hardware failure), the NullifierRegistry supports governance-authorized revocation with manual re-enrollment under supervised conditions. This process requires a quorum signature from the governance authority and is designed to be deliberate and auditable, not automated.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

7. SPT-Txn: Transaction Token Integration

7.1 IETF Txn-Token Limitations

The IETF Transaction Token specification (draft-ietf-oauth-transaction-tokens) solves identity propagation in microservice call chains. However, it lacks capability scoping per hop, has no agentic delegation depth model, propagates user identity in plaintext, assumes single-organization deployment, and carries no compliance attestations. SPT-Txn extends Txn-Tokens with five additions.

7.2 SPT-Txn Extension Claims

```
SPT-Txn JWT additional claims (extending IETF base):

  spt_human_anchor:    bytes32  zkDID commitment of root authorizing human
                                Identical in all tokens in the chain
                                Replaces plaintext 'sub' for downstream
  spt_ct_ref:          bytes32  Hash of CT held by this hop's caller
  spt_ct_scope_hash:   bytes32  Hash of CT capability scope at this hop
  spt_delegation_depth:uint8    Current depth in delegation tree
  spt_max_depth:       uint8    Ceiling set at root — never changes
  spt_compliance_ref:  bytes32  Hash of ZK compliance proof set at root
  spt_oracle_commit:   bytes32  Oracle Merkle root for proof freshness check
  spt_trust_registry:  string   URI of Trust Registry for cross-org CT verify
  spt_parent_ct_ref:   bytes32  Hash of parent CT in delegation chain
```

7.3 Complete Agentic Transaction Flow

```
Human (H, biometric+KYC verified) → ABAC PDP
  Root CT:     { scope:S_H, depth:3, anchor:H.zkDID }
  Root TxnTok: { spt_human_anchor:H.anchor,
                 spt_ct_ref:hash(CT_H),
                 spt_delegation_depth:3,
                 spt_compliance_ref:hash(ZK_proofs) }

H delegates to AI Agent A1:
  CT_A1:       { scope:S_A1⊆S_H, depth:2, anchor:H.zkDID }
  TxnTok_A1:   { ...root, workload_chain:[A1.id appended] }

A1 calls Service S1 (Org B):
  CT_S1:       { scope:S_S1⊆S_A1, depth:1, anchor:H.zkDID }
  TxnTok_S1:   { ...A1, workload_chain:[S1.id appended] }
  S1 verifies CT_S1: sig+scope+revocation+trust_registry
  NO call to Org A authorization server required.

S1 calls Service S2 (Org C):
  CT_S2:       { scope:S_S2⊆S_S1, depth:0, anchor:H.zkDID }
  depth:0 — S2 cannot issue further delegation CTs
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

```
Audit trail: H.anchor → A1 → S1 → S2 (immutable, tamper-evident)
Every hop:   CT reference + scope hash + depth + compliance reference
Any party:   Can verify human authorized root without seeing PII
```

7.4 Token Format Considerations

The SPT-Txn framework specifies JWT (RFC 7519) as the primary Capability Token format for interoperability with the IETF OAuth ecosystem and existing enterprise infrastructure. However, the framework defines a token-format-agnostic interface at the TBAC enforcement boundary, enabling alternative token formats where their security properties provide stronger guarantees for specific deployment scenarios. Three token formats are supported in a tiered model.

Primary Format: JWT with Selective Disclosure (SD-JWT). The IETF SD-JWT specification (draft-ietf-oauth-selective-disclosure-jwt) extends JWT to support selective claim disclosure, enabling a holder to reveal only the claims required by a specific verifier. In the SPT-Txn context, an AI agent presenting a Capability Token to a settlement service can disclose only the scope:settle claim without revealing that the CT also authorises scope:trade. This directly supports the data minimisation principle and strengthens the GDPR compliance arguments presented in Section 19.1. SD-JWT is on the IETF standards track and aligns with the framework's positioning within the OAuth Working Group. The IETF draft (draft-coetzee-oauth-spt-txn-tokens) specifies JWT/SD-JWT as the normative token format for cross-organisational interoperability.

Alternative Format: Biscuit Tokens. Biscuit (biscuitsec.org) is an append-only bearer credential format with Datalog-based authorisation logic. Its core security property is cryptographic attenuation: each delegation hop appends a new block that can only restrict, never expand, the token's authority. This maps directly to the SPT-Txn scope narrowing invariant (Section 4.3), where scope(child) must be a subset of scope(parent). With JWT, scope narrowing is enforced by the TBAC engine at evaluation time; with Biscuit, it becomes a structural invariant of the token format itself. The delegation depth decrement, scope constraint propagation, and humanAnchor immutability specified in Sections 3.4 and 10.1 can be expressed as Biscuit authorisation policies, moving enforcement from application logic to token-level cryptographic guarantees. The trade-off is that Biscuit is not an IETF standard and has a smaller ecosystem footprint than JWT.

Agent-to-Agent Format: CWT (CBOR Web Token, RFC 8392). For high-throughput agent-to-agent communication within a single trust domain, the framework supports CBOR Web Tokens. CWT provides the same security model as JWT but uses COSE-based binary serialisation, yielding significantly smaller token sizes and faster parsing. This is relevant to the throughput targets specified in Section 18.4 (1,000+ transactions per second). CWT is particularly suited for intra-organisation delegation chains where agents communicate over constrained channels, while JWT/SD-JWT remains the normative format for cross-organisational token exchange.

Format Selection Mapping. Implementations select the token format based on deployment context: JWT/SD-JWT for cross-organisational Capability Token exchange and IETF-compliant deployments; Biscuit for deployments requiring cryptographically enforced attenuation, particularly deep delegation chains (depth > 3) where application-level scope validation carries higher risk; and CWT for agent-to-agent communication within a single trust domain where

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

throughput and token size are binding constraints. The TBAC enforcement engine (Section 4.2) accepts all three formats through a unified verification interface, with format-specific parsing isolated behind a token adapter layer. This ensures that the eight-step enforcement logic remains format-agnostic.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

8. ZK and Biometric Layers — Summary

8.1 zkDID — Unlinkable Identity

The DID is never transmitted. The subject proves knowledge of a valid DID commitment via ZK proof (Circuit 1). CTs and AGTs are issued to one-time stealth addresses derived from ZK commitments, cross-session correlation is cryptographically impossible. The humanAnchor in every CT is the zkDID commitment, never a raw identifier. For full circuit specification see Section 5.

8.2 Biometric Uniqueness

Sybil resistance is provided by the fuzzy commitment scheme executed entirely within the hardware secure enclave. The biometric never leaves the device. The nullifier registry enforces global uniqueness. Recovery is governance-gated and permanent by design. For full enrollment contract architecture see Section 6.

8.3 Liveness and Hardware Attestation

Every biometric proof includes a liveness attestation signed by the device hardware root of trust (Apple Secure Enclave / Android StrongBox / FIDO2 authenticator). The CT issuer verifies liveness passed on certified hardware before issuing any root CT. This attestation is transitively trusted by all downstream enforcement points via the humanAnchor claim.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

9. Trust Model

9.1 Configurable Trust Anchors

Configuration	Trust Anchor	Use Case	Legal Recognition
Independent	On-chain governance + biometric uniqueness	DAOs, civil society, pseudonymous communities	None required
Issuer-Delegated	Licensed KYC/AML provider	Regulated exchanges, financial services	Full regulatory compliance
Governance-Based	On-chain Trust Registry by regulatory body	Cross-jurisdictional regulated infrastructure	Jurisdiction-specific
Hybrid (recommended)	Layer 1 independent + Layer 2 regulated bridge	Universal deployment	Selective, user-controlled

9.2 The Human-in-the-Loop Cryptographic Guarantee

The humanAnchor field carried in every CT and SPT-Txn token provides a property no current AI governance framework has technically implemented: cryptographic proof that a biometrically-verified, KYC-attested human authorized the root of every agentic transaction chain. Regulators asking 'who authorized this AI agent action?' receive a cryptographic proof, not a log entry.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

10. AI Agent Authorization

10.1 The Formal Delegation Model

```
PRINCIPAL HIERARCHY:

  Human (H)          CT_H:   { scope:S_H,   depth:D,   anchor:H.zkDID }
    Agent (A1)       CT_A1:  { scope:S_A1,  depth:D-1, anchor:H.zkDID }
      Agent (A2)     CT_A2:  { scope:S_A2,  depth:D-2, anchor:H.zkDID }
        Svc (S1)     CT_S1:  { scope:S_S1,  depth:D-3, anchor:H.zkDID }
          Svc (S2)   CT_S2:  { scope:S_S2,  depth:0,   anchor:H.zkDID }

ENFORCED INVARIANTS:
  S_A1 ⊆ S_H    S_A2 ⊆ S_A1   S_S1 ⊆ S_A2   S_S2 ⊆ S_S1
  anchor immutable throughout   depth = 0 ⇒ no further delegation

REVOCATION CASCADE:
  revoke(CT_H)  ⇒ CT_A1, CT_A2, CT_S1, CT_S2 all invalid
  revoke(CT_A1) ⇒ CT_A2, CT_S1, CT_S2 invalid; CT_H unaffected
  revoke(CT_A2) ⇒ CT_S1, CT_S2 invalid; CT_H, CT_A1 unaffected
```

10.2 AI Governance Impact

Regulators ask: *"When your AI agent caused harm, who authorized it, to what scope, and can you prove it?"*

Current industry answer: We have logs. Trust us.

SPT-Txn answer: The authorizing human is biometrically verified and KYC-attested, cryptographically provable. Every capability delegation is a signed CT with explicit scope, on-chain, immutable. Every transaction carries a full chain-of-custody Txn-Token. Scope violations are impossible at the enforcement layer, not merely policy-prohibited. The entire chain is auditable by regulators using ZK proofs without accessing PII.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

11. Multi-Chain Deployment Architecture

The SPT-Txn Framework is chain-agnostic by design. The ZK circuits, TBAC enforcement engine, token primitives, and IETF Txn-Token extension are specified independently of any particular blockchain. Five reference implementations address distinct deployment contexts and client profiles.

Dimension	EVM / Polygon	XDC Network	Hedera Hashgraph	Cardano / Midnight	Substrate
Primary focus	DeFi / general	Trade finance / RWA	Enterprise auth + audit	ZK-native privacy	Enterprise sovereign
Consensus	PoS	DPoS	aBFT Hashgraph	Ouroboros PoS	BABE/GRANDPA
Finality type	Probabilistic	Probabilistic	ABSOLUTE (aBFT)	Probabilistic	Probabilistic
Finality time	~2 seconds	~2 seconds	3-5 seconds	~20 seconds	~6 seconds
TPS	~7,000	~2,000	10,000+	~250	~1,000+
EVM compatible	Yes (native)	Yes (full EVM)	Yes (HEVM)	No	ink! (Rust)
ZK layer	Noir	Noir (EVM)	Noir (HEVM)	Midnight native ZK	arkworks (Rust)
Privacy model	Application layer	Application layer	Application layer	Protocol layer	Custom runtime
Native compliance tokens	No	No	YES — HTS	No	Custom pallet
Audit trail service	No	No	YES — HCS	No	Custom
ISO 20022	No	Yes — native	No	No	Configurable
SWIFT bridge	No	Yes — XinFin	No	No	Custom
DID/SSI	did:ethr + Veramo	did:ethr + Veramo	did:ethr + Veramo	Atala PRISM	Custom pallet
Fee model	Variable gas	Near zero	Fixed USD ~$0.001	Low	Configurable
Mainnet status	Production	Production	Production	Midnight: pre-prod	Custom
Smart contracts	Solidity	Solidity	Solidity (HEVM)	Plutus / Compact	ink! (Rust)
Grant funding	Polygon Village	XDC Foundation	HBAR Foundation	Catalyst	Web3 Foundation

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Dimension	EVM / Polygon	XDC Network	Hedera Hashgraph	Cardano / Midnight	Substrate
Institutional trust	DeFi native	Trade finance	Google, Deutsche Bank, IBM	IOG / academic	Enterprise

** Hedera Governing Council (39 members) includes: Google, IBM, Boeing, Deutsche Bank, Standard Bank, Shinhan Bank, Swisscom, LG Electronics, ServiceNow, and 29 additional global enterprises.*

11.1 EVM — Primary Reference Implementation

The EVM implementation on Polygon (or Base) is the primary development target. Maximum ecosystem compatibility, largest Solidity developer pool, most ZK tooling (Noir generates EVM verifier contracts directly), most KYC provider and exchange integrations, and the deepest institutional familiarity for DeFi and digital asset platforms. Recommended for: DeFi integrations, exchange pilots, fastest time to market.

Polygon ID's existing ZK identity infrastructure provides a directly compatible parallel implementation that can bridge into the SPT-Txn CAT layer. This creates an accelerated integration path with platforms already using Polygon ID for identity.

11.2 XDC Network — RWA and Trade Finance Implementation

XDC Network is purpose-built for the institutional financial services use cases that the SPT-Txn compliance layer directly addresses. ISO 20022 native messaging, SWIFT bridge connectivity, and active engagement with trade finance bodies and multilateral institutions (including IMF and World Bank pilot involvement) make XDC the correct chain for Real World Asset tokenization and cross-border trade finance deployments.

XDC's hybrid architecture, a public chain for liquidity with permissioned enterprise subnetworks, maps precisely onto the SPT-Txn trust model: independent Layer 1 for general access, enterprise subnetwork for regulated institutional deployments. Because XDC is fully EVM-compatible, all Solidity contracts from the primary EVM implementation deploy on XDC without modification.

Specific SPT-Txn alignment: FATF Travel Rule compliance for tokenized asset transfers, cross-border KYC portability for institutional counterparties, ISO 20022-compliant authorization metadata in trade finance workflows, and regulatory compliance proof propagation in XDC's existing institutional network.

11.3 Hedera Hashgraph — Enterprise Authorization and Audit Trail

Hedera Hashgraph is architecturally distinct from all other chains in this framework. It is not a blockchain, it is a Directed Acyclic Graph (DAG) using a gossip-about-gossip protocol with virtual voting consensus. This architecture provides asynchronous Byzantine Fault Tolerant (aBFT) consensus, the strongest security guarantee available: finality is mathematically proven, not statistically probable. Once a transaction is confirmed on Hedera (3-5 seconds), it is final. No reorganization is possible.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

For SPT-Txn specifically, aBFT absolute finality addresses a compliance requirement that probabilistic chains cannot satisfy. Regulated financial institutions and central banks treat settlement finality as a binary property, a transaction is either final or it is not. Hedera provides this guarantee. Polygon, XDC, and Cardano provide probabilistic finality only.

Hedera Token Service (HTS): HTS provides protocol-native compliance tokens without smart contracts. The KYC flag restricts token holding to verified accounts. The freeze mechanism halts individual account activity. The wipe mechanism enables instant CT revocation at protocol level. The pause mechanism halts all transfers globally. These are not smart contract operations, they are consensus-layer primitives, making them faster, cheaper, and more reliable than their EVM equivalents. CATs, Policy NFTs, and Capability Tokens implemented via HTS inherit these compliance properties natively.

Hedera Consensus Service (HCS): HCS provides immutable, timestamped message ordering without requiring smart contract execution. Every CT issuance, every Txn-Token delegation hop, and every revocation event can be anchored to an HCS topic at ~$0.0001 per message with absolute finality. This creates a tamper-evident, regulator-accessible audit trail for the entire SPT-Txn chain-of-custody at negligible cost. HCS is the ideal technical substrate for the SPT-Txn transaction chain audit requirements.

Governing Council: The Hedera Governing Council comprises 39 term-limited global enterprises including Google, IBM, Boeing, Deutsche Bank, Standard Bank, Shinhan Bank, Swisscom, and LG Electronics. For regulated financial services deployments, the governing council provides institutional credibility that no other chain in this framework matches. When a bank's compliance officer asks 'who governs this infrastructure?' Deutsche Bank and Standard Bank on the governing council is a materially different answer than a developer foundation or a single company.

HBAR Foundation Grants: The HBAR Foundation funds projects in identity, verifiable credentials, enterprise authorization, and regulatory technology, all directly applicable to SPT-Txn. Grant amounts range from $50,000 to $2M+ for strategic projects with no equity dilution. The identity and sustainable impact tracks are the primary targets for SPT-Txn Phase 1 funding.

Google alignment: Google is a Hedera governing council member and offers Hedera node services on Google Cloud. For the AI company outreach strategy, specifically targeting Google's Gemini and Vertex AI agent authorization infrastructure, Hedera deployment creates a natural alignment that EVM chains do not provide.

SPT-Txn on Hedera — component mapping:

```
CATs:              HTS non-fungible tokens with KYC flag
                   Only KYC-verified accounts can hold CATs
Policy NFTs:       HTS NFTs or HEVM Solidity contracts
Capability Tokens: HTS tokens with freeze + wipe + expiry
                   Revocation = wipe (protocol-level, instant)
Nullifier Registry:HEVM smart contract
Trust Registry:    HEVM smart contract
ZK Proofs:         Noir circuits + HEVM Solidity verifier
                   Same circuits as EVM implementation
Txn-Token chain:   HCS topics (immutable, timestamped,
                   absolutely final, $0.0001/message)
Revocation log:    HCS + HEVM (HCS for audit, HEVM for check)
```

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Fixed fee model: Hedera fees are priced in USD and converted to HBAR at spot rate, providing predictable operational costs. CT issuance: ~$0.001. HCS message: ~$0.0001. Enterprise financial planning is viable — no gas spike events. For a compliance verification product at scale, fixed costs per verification enable accurate margin modeling.

11.4 Cardano / Midnight — ZK-Native Privacy Implementation

Cardano's Midnight sidechain is the architecturally most aligned platform for the SPT-Txn ZK layer. Midnight's Zswap protocol provides ZK proofs as a first-class runtime primitive, not an application-layer add-on. Shielded transactions on Midnight natively hide amounts and parties, providing the protocol-level privacy that Polygon and XDC achieve only at application layer.

Atala PRISM, IOG's production DID/SSI infrastructure on Cardano, provides a directly compatible DID substrate for the CAT layer. Atala PRISM is already deployed at national scale, Ethiopia's Ministry of Education issued credentials to over five million students on Atala PRISM, providing production proof-of-concept for the credential portability model that CATs implement. The formal verification approach of Plutus smart contracts (Haskell-based, peer-reviewed) matches the academic rigor of the SPT-Txn white paper.

Midnight deployment note: Midnight is pre-production as of this writing. The Compact language (TypeScript-like) for Midnight contracts is more accessible than Plutus/Haskell. The ZK-native proof primitives in Midnight eliminate the need for Noir circuits for the primary ZK layer, the proof statements specified in Section 5 are implemented natively by the Midnight runtime.

11.5 Substrate — Enterprise Sovereign Implementation

Substrate (Polkadot ecosystem) enables deployment of the SPT-Txn Framework as a custom blockchain runtime, a parachain, with precisely the primitives needed. FRAME pallets provide modular, composable runtime components for identity, governance, and policy enforcement. On-chain governance is built in. The Rust-based ink! smart contract language provides performance and memory safety properties appropriate for high-value institutional deployments.

The Substrate deployment is not a general-purpose chain, it is a dedicated authorization infrastructure parachain designed for organizations requiring full sovereignty over their authorization runtime: central bank digital identity programs, national-scale credential systems, and large financial institutions requiring air-gapped or permissioned chain operation. Polkadot's XCM cross-chain messaging enables interoperability with other parachains without sacrificing sovereignty.

11.6 Chain-Agnostic Design Principles

Three design principles ensure chain-agnosticism across all five implementations:

- ZK proof statements (Section 5) are specified in mathematical terms, not circuit language. The Noir implementation is the EVM/XDC reference. Midnight native ZK is the Cardano reference. arkworks is the Substrate reference. The proof statements are identical.
- Token interfaces (Section 3) are specified as abstract data structures. ERC-721/1155 is the EVM encoding. Cardano native tokens with metadata is the Cardano encoding. Custom pallets are the Substrate encoding.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

- The TBAC Enforcement Engine (Section 4.2) is a pure function over the CT payload. It has no chain dependency. The same eight-step logic applies regardless of which chain the CT was issued on.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

12. Commercial Applications and Market Opportunity

SPT-Txn is not a product. It is authorization infrastructure, the same position that Stripe occupies for payments or Twilio for communications. It is the layer everyone in the regulated digital economy needs, built once to a rigorous standard, and made available to every platform that cannot justify building it themselves. The commercial opportunity follows directly from five markets that are structurally broken, each in a way that SPT-Txn resolves at its root.

12.1 Portable KYC — Eliminating the World's Most Expensive Re-Work

The Problem

The global financial system re-verifies the same person's identity every time they open a new account at a new institution. A corporate client seeking relationships at five banks submits its documentation, passports, incorporation certificates, proof of address, beneficial ownership registers, source of funds evidence, five separate times to five separate compliance teams. Each review is conducted from scratch, ignoring every prior verification that has already happened elsewhere.

According to Fenergo's global research surveying over 1,000 C-suite executives at major banks, 54% of corporate and institutional banks spend between $1,500 and $3,000 to complete a single client KYC review, and 21% spend more than $3,000 per review. Large financial institutions spend up to $35 million annually on KYC for new clients alone. By 2025, the average KYC compliance cost across banks, asset managers, and fund administrators had reached nearly $73 million per firm annually, and rising, as regulatory complexity continues to increase.

The cost of this duplication falls on both sides. Financial institutions spend the money; clients bear the delay. Fenergo's 2025 survey of 600 senior decision-makers found that 70% of financial institutions worldwide lost clients in the prior year due to slow onboarding, the highest rate ever recorded. Client abandonment during onboarding averages around 10%. The KYC process that is supposed to protect the financial system is actively destroying revenue. Regulators are not satisfied either: AML fines globally reached $6.6 billion in 2023.

The Scale

According to PwC, financial institutions face annual regulatory compliance costs exceeding £33.9 billion, over 13% of total operational expenditure. A significant share of this is pure re-verification: re-doing work that has already been done correctly, at another institution, whose results cannot be trusted across organizational boundaries because there is no portable proof mechanism.

The SPT-Txn Answer

One verification. One set of ZK compliance proofs bound to the user's zkDID. Every subsequent institution presents those proofs to their ABAC Policy Decision Point, which evaluates them against their Policy NFT in milliseconds and issues a scoped Capability Token. The compliance officer receives a stronger guarantee than manual document review provides: a ZK proof generated against an oracle-committed, timestamped KYC state that cannot be altered retroactively. The user submits no documents. The institution pays a verification fee, not a review fee.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

The Portable KYC Commercial Case

Current cost per full KYC review (corporate):	$1,500 - $3,000+ (Fenergo, 2022)
SPT-Txn cost per ZK verification:	< $1
Cost reduction:	99%+
Client abandonment rate (2025 avg):	~10% (Fenergo, 2025)
Institutions that lost clients to slow KYC:	70% globally (Fenergo, 2025)
Global AML fines (2023):	$6.6 billion
Global AML fines (2024):	$4.6 billion

Who wins: Banks, exchanges, asset managers (cost elimination)
KYC providers (network distribution effect)
Unbanked users (friction barrier removed)
Regulators (stronger proof than manual review)

12.2 Cross-Jurisdictional Regulatory Composability — One Credential, Every Market

The Problem

A digital asset platform operating across Dubai (VARA), El Salvador (CNAD), the European Union (MiCA), and the United States (FinCEN) maintains four legally distinct compliance programs. Four separate legal teams. Four separate technical integrations. Four separate customer verification workflows. A customer who is fully compliant in all four jurisdictions still cannot carry that compliance across platforms, each institution re-verifies from zero because no portable compliance mechanism exists.

Cross-border capital flows that should be machine-speed are gated on manual bilateral compliance agreement negotiations that cost $500,000 to $2 million each to establish and maintain. As tokenized assets and digital platforms proliferate across jurisdictions, this per-bilateral scaling model collapses. A platform entering ten new jurisdictions faces ten independent compliance buildouts.

The Scale

The RWA tokenization market stood at approximately $24-30 billion on-chain in mid-2025, growing from $85 million in 2020. Forecasts from BCG and ADDX project a $16 trillion tokenization opportunity by 2030; the BCG and Ripple joint analysis projects $9.4 trillion in tokenized demand by 2030, rising to approximately $18.9 trillion by 2033. McKinsey's more conservative baseline projects $2-4 trillion. Across all credible forecasts, the direction is unambiguous: trillions of dollars of assets will need cross-jurisdictional compliance infrastructure at scale that does not yet exist.

The SPT-Txn Answer

Policy NFTs encoding VARA, CNAD, MiCA, and FinCEN compliance requirements are published on-chain by jurisdictional compliance authorities or licensed issuers. A user whose ZK compliance proofs satisfy all four Policy NFTs simultaneously is instantly eligible on any composable platform in any of those jurisdictions. No bilateral agreement required. No manual review. Compliance is not bypassed, it is satisfied cryptographically, once, and the proof travels with the user.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

For RWA platforms specifically, the Policy NFT composability model means that a tokenized real estate fund, a private credit instrument, or a tokenized Treasury can be structured with Policy NFTs encoding its eligibility requirements, accredited investor status, jurisdiction, AML clearance, and any eligible user globally can access it instantly, with automated regulatory satisfaction at every step.

12.3 Travel Rule Compliance for the Agentic Economy

The Problem That Does Not Yet Have an Industry Solution

FATF's Recommendation 16, the Travel Rule, requires originator and beneficiary identity information to accompany every virtual asset transfer above $1,000 (or $3,000 in some jurisdictions). For human-to-human transfers between identified VASPs, existing messaging protocols provide a workable, if fragmented, solution. For AI agent transactions, there is currently no solution at all.

When an AI agent autonomously executes a cross-border asset transfer on behalf of a human, routing through multiple exchanges, bridges, and custodians across two jurisdictions, who is the originator? Which VASP is responsible for Travel Rule compliance? What is the beneficiary's identity? The agent is not a legal person. The human who authorized the agent may be several delegation hops away. Current Travel Rule infrastructure was designed for human-initiated bilateral transfers. It has no model for agentic transaction chains.

This is not a future problem. AI agents are executing financial transactions today. JPMorgan has deployed AI tools used by approximately 50,000 employees. Goldman Sachs, BlackRock, and every major institution is actively expanding AI deployment into financial operations. Regulatory agencies are watching. The gap between what regulators require and what the industry can technically demonstrate is widening with every agent deployment.

The SPT-Txn Answer

The humanAnchor field carried in every SPT-Txn token is the cryptographic originator, the biometrically-verified, KYC-attested human who authorized the root of the transaction chain. The spt_compliance_ref carries ZK-attested KYC and AML claims from that root through every delegation hop. The licensed issuer holds the Travel Rule-required originator information and responds to lawful VASP-to-VASP information requests. The transaction chain itself, anchored on Hedera Consensus Service with absolute finality, provides the tamper-evident audit record that regulators can inspect.

The result: Travel Rule compliance for agentic transactions without requiring agents to hold or transmit PII, without breaking the privacy architecture, and without creating a new regulatory burden on the platforms that deploy agents. Compliance is embedded in the authorization chain from the root.

12.4 AI Agent Authorization — The Defining Infrastructure Gap of the Decade

The Market

The AI in Finance market is projected to grow from $38.36 billion in 2024 to $190.33 billion by 2030 at a CAGR of 30.6%, according to MarketsandMarkets. The agentic AI segment specifically, autonomous agents executing tasks with minimal human intervention, is projected to grow from $5.51 billion in 2025 to $33.26 billion by 2030 at a CAGR of 43.3% (Mordor Intelligence). A Capgemini survey found that while only 10% of companies currently deploy AI agents, 82% plan

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

to adopt them within three years. In financial services specifically, adoption jumped from 19% to 31% in a single year.

The Authorization Gap

Every AI agent platform deploying agents in financial services, Anthropic with Claude Code, Claude in Chrome, Claude in Excel; OpenAI with GPT agents; Microsoft with Copilot; Google with Gemini agents, is selling into regulated industries where one question cannot currently be answered: when the agent took that action, what exactly was it authorized to do, by whom, to what scope, and can you cryptographically prove it?

The current industry answer is: we have logs. An application log is not a proof. It is a mutable record created by the system being examined, with no cryptographic guarantee of integrity or completeness. It does not specify what the agent was authorized to do, only what it did. It does not carry a verifiable chain of delegation back to a human principal. It cannot be used as evidence of scoped authorization in a regulatory investigation or legal proceeding.

The Regulatory Forcing Function — Already Law

EU AI Act Article 14 (Human Oversight) becomes enforceable on August 2, 2026. The Act, which entered into force on August 1, 2024 and applies fully from August 2, 2026, requires that high-risk AI systems be designed to allow effective oversight by natural persons. Article 14 mandates that humans can monitor the system, detect anomalies, interpret outputs, and override or stop the system when necessary. For AI agents operating in financial services, credit assessment, risk scoring, transaction monitoring, portfolio management, this is not advisory guidance. It is enforceable law with penalties up to 7% of global annual revenue for non-compliance.

There is no technical standard for what Article 14 human oversight means in an agentic transaction context. The EU has published the requirement without specifying the mechanism. SPT-Txn provides the mechanism: the humanAnchor is the cryptographic proof of human authorization at the root of every agentic chain. The CT scope is the cryptographic proof of what the agent was authorized to do. Revocation is the cryptographic mechanism for human intervention and override. The HCS-anchored Txn-Token chain is the tamper-evident audit record that regulators can inspect.

A Gartner report (February 2026) noted that 88% of organizations use AI operationally but only 18% have fully implemented AI governance frameworks. The AI governance platform market is projected to reach $492 million in spending in 2026 alone, growing to over $1 billion by 2030. This is the compliance infrastructure buildout that Article 14 is forcing, and SPT-Txn is the authorization layer at its technical foundation.

Who Needs This — Named

Company / Platform	Agent Product	The Authorization Problem	The SPT-Txn Solution
Anthropic	Claude Code, Claude in Chrome, Claude in Excel, Claude Cowork	Claude agents acting in financial workflows have no scoped authorization record. Enterprise sales require compliance accountability.	CT scoping per agent. humanAnchor links every action to authorizing human. Cryptographic proof for enterprise compliance teams.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Company / Platform	Agent Product	The Authorization Problem	The SPT-Txn Solution
OpenAI	GPT-4o with tools, GPT agents via API	Same authorization gap. Financial services customers increasingly requiring audit trails that do not exist.	Same CT delegation model. SPT-Txn SDK integrates at the agent invocation layer.
Microsoft	Copilot in M365, Azure AI agents	Copilot accessing financial documents, drafting transactions, executing workflows. Authorization scope not cryptographically bounded.	Extends existing Azure Entra ID delegation model with cryptographic CT scoping and immutable audit trail.
Google	Gemini agents, Vertex AI	Same agent authorization gap in Google Cloud financial services deployments. Google is also a Hedera Governing Council member.	Hedera deployment creates internal alignment. Google Cloud + Hedera + SPT-Txn is a natural enterprise stack.
Major banks (JPMorgan, Goldman, BlackRock)	Internal AI agents deployed at scale	Regulatory exposure from AI actions without bounded authorization. Article 14 deadline creates urgency NOW.	SPT-Txn is the authorization governance layer that makes AI agents auditable without slowing them down.

The Infrastructure Argument

AI companies cannot build this infrastructure themselves. **Authorization standardization requires a neutral third party.** If Anthropic builds its own authorization layer and OpenAI builds a different one, enterprise customers cannot audit multi-vendor agent pipelines. Regulators cannot enforce consistently across platforms. The authorization question, who authorized what, to what scope, through what chain, requires a cross-platform standard. SPT-Txn, grounded in an IETF Internet-Draft, is positioned as that standard. The white paper and IETF draft are the credentials that initiate that conversation.

12.5 RWA Tokenization Infrastructure — Compliance at the Scale of Traditional Finance

BlackRock's BUIDL tokenized money market fund surpassed $2.9 billion. Franklin Templeton, Apollo, JPMorgan, and Goldman Sachs have all moved from tokenization pilots to production-scale deployments. The on-chain RWA market grew from $85 million in 2020 to approximately $24-30 billion by mid-2025, nearly a 300-fold increase in five years. Every credible forecast projects multi-trillion-dollar scale by 2030: BCG and ADDX project a $16 trillion opportunity; McKinsey projects $2-4 trillion in tokenized value; Ripple and BCG project $9.4 trillion in demand by 2030.

Every tokenized asset requires three things that SPT-Txn provides natively: verified investor eligibility (accredited investor status, jurisdiction, KYC/AML clearance), compliant transfer restrictions (only eligible parties can hold or trade), and regulatory audit trail (every transfer with full compliance evidence). Policy NFTs encode the eligibility requirements for each asset. CATs

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

carry the investor's verified credentials. ABAC evaluation at transfer time issues a CT only to eligible holders. The entire compliance workflow, onboarding, eligibility verification, transfer restriction enforcement, audit trail, is automated and cryptographically guaranteed.

On XDC Network, where SPT-Txn deploys natively via EVM compatibility, ISO 20022 authorization metadata travels with the transaction, making the compliance record directly compatible with correspondent banking infrastructure. This is the bridge between on-chain tokenized assets and the traditional financial system's reporting and settlement requirements.

12.6 Revenue Architecture and Unit Economics

The SPT-Txn revenue model captures value at the authorization layer, the same position in the stack as payment processors, communication APIs, and cloud identity providers. Every regulated interaction in the digital economy that requires identity verification, compliance proof, or capability authorization is a billable event. The model scales horizontally with volume and compounds as the network of integrated platforms grows.

Revenue Stream	Mechanism	Unit Economics	Primary Customers
ZK Verification Fees	Per compliance proof verification	$0.10 - $0.50 per verification vs $1,500-$3,000 manual KYC cost	Regulated exchanges, DeFi protocols, banks, asset managers
Policy NFT Marketplace	Jurisdiction compliance templates	$5,000 - $50,000 per jurisdiction template license	Compliance teams, legal technology firms, new market entrants
Compliance-as-a-Service API	Monthly platform subscription	$5,000 - $50,000/month per platform tier	Mid-tier exchanges, FinTechs, crypto platforms
Enterprise Deployment License	Annual white-label license	$250,000 - $2,000,000 per annum	Major banks, asset managers, custodians
AI Agent Authorization SDK	Per-agent-transaction fee	$0.001 - $0.01 per agent transaction	Anthropic, OpenAI, Microsoft, Google, enterprise AI deployers
KYC Provider Revenue Share	Distribution network fee	15-30% of provider verification fee	Sumsub, Onfido, Veriff, Jumio — mutual value creation
RWA Transfer Compliance Fee	Per tokenized asset transfer	$0.50 - $5.00 per compliant transfer	RWA platforms, tokenized fund managers, custodians
HCS Audit Anchoring (Hedera)	Per transaction audit record	Fixed at Hedera protocol rates (~$0.0001)	All regulated deployments requiring audit trail

Illustrative Scale — What Volume Means

Scenario	Volume Assumption	Annual Revenue Estimate	Notes
Conservative — 3 enterprise deployments	3 enterprise licenses + 500K verifications/yr	~$1.5M - $3M	Pre-product-market fit; consulting + early licensing

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Scenario	Volume Assumption	Annual Revenue Estimate	Notes
Growth — 20 platforms, 10M verifications/yr	Platform subscriptions + verification fees	~$8M - $20M	Series A stage; demonstrable traction
Scale — 100 platforms, 500M verifications/yr	Mix of all revenue streams	~$75M - $200M	Category leadership established; AI SDK gaining adoption
Infrastructure — AI agent transactions at scale	10 billion agent transactions/year at $0.005	~$50M from agents alone	One revenue stream at conservative adoption rates

These figures are illustrative, not projected. They demonstrate that the revenue model is viable at multiple stages of adoption and scales in proportion to market growth, particularly the AI agent authorization stream, which scales directly with the agentic AI market projected to reach $33 billion in financial services alone by 2030.

Non-Dilutive Funding — HBAR Foundation

The HBAR Foundation funds projects in identity, verifiable credentials, enterprise authorization, and regulatory technology, all directly applicable to SPT-Txn. Grant amounts range from $50,000 to $2 million or more for strategic projects, with no equity dilution. The identity and sustainable impact tracks are the primary targets for SPT-Txn Phase 1 funding, providing a credible non-dilutive path to prototype capital before an equity raise is required.

12.7 Market Sizing — TAM, SAM, SOM

The SPT-Txn Framework addresses three converging markets: identity verification and portable KYC, AI agent authorization infrastructure, and tokenized asset compliance. Market sizing combines top-down market research and bottoms-up unit economics to derive a serviceable obtainable market consistent with the revenue model specified in Section 12.6.

Market	TAM (Total Addressable)	Source / Forecast	Growth Rate
Identity Verification	3.7B (2024) → 9.3B (2030)	MarketsandMarkets, 2024	CAGR 15.4%
AI in Financial Services	8.4B (2024) → 90.3B (2030)	MarketsandMarkets, 2024	CAGR 30.6%
Agentic AI (Financial Services)	.5B (2025) → 3.3B (2030)	Mordor Intelligence, 2025	CAGR 43.3%
RWA Tokenization (on-chain)	4-30B (2025, current) → .4T (2030, BCG/Ripple)	BCG/Ripple 2024; McKinsey 2024	Nascent → exponential
AI Governance Platforms	/bin/sh.49B (2026) → B+ (2030)	Gartner, February 2026	~30% CAGR
KYC Compliance Cost (addressable)	3M avg per institution × 10,000+ institutions globally	Fenergo, 2025	Rising with regulatory complexity

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

SAM — Serviceable Addressable Market

SPT-Txn's serviceable market is regulated financial services platforms that require portable identity, cross-jurisdictional compliance, AI agent authorization, or tokenized asset compliance infrastructure. This excludes general consumer identity, unregulated platforms, and markets where full KYC compliance is not required.

SAM Component	Estimate	Derivation
Regulated exchanges and FinTechs requiring portable KYC	.5B by 2030	~50% of identity verification market that overlaps with regulated crypto/digital asset services
AI agent authorization (regulated enterprise)	B by 2030	~10% of agentic AI market in financial services; authorization middleware typically 5-15% of agent infrastructure spend
RWA platform compliance infrastructure	.5B by 2030	~0.016% of projected RWA market value; compliance infrastructure cost for tokenized asset platforms
Total SAM	~B by 2030	Conservative estimate; upside driven by RWA market reaching BCG/Ripple projection

SOM — Serviceable Obtainable Market

Authorization middleware and compliance infrastructure providers typically capture 1-3% of their serviceable market within five years of product launch, based on comparable categories: API-first payments infrastructure, communication APIs, and cloud identity platforms. Applying this range to SPT-Txn's SAM:

SOM Scenario	SAM Capture Rate	Estimated Revenue by 2030	Bottoms-Up Cross-Check
Conservative	1% of B SAM	0M	~20 enterprise licenses at .5M avg + 500M verifications at /bin/sh.10 + 5B agent transactions at /bin/sh.005
Base Case	1.5% of B SAM	05M	~35 enterprise licenses + 1B verifications + 15B agent transactions
Optimistic	3% of B SAM	10M	~70 enterprise licenses + 3B verifications + 30B agent transactions; assumes early AI governance standards adoption

These SOM estimates are consistent with the illustrative revenue scenarios in Section 12.6 and demonstrate internal coherence between the top-down market sizing and the bottoms-up unit economics. The AI agent authorization stream is the highest-upside variable: if AI governance mandates (EU AI Act Article 14 enforcement from August 2026) accelerate enterprise adoption, agent transaction volume could exceed these estimates by an order of magnitude.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Market Sizing Methodology Notes

TAM figures use most recently published market research with identified sources.

MarketsandMarkets and Mordor Intelligence figures are widely cited industry research.

BCG/Ripple RWA projection is the most optimistic credible forecast; McKinsey provides conservative anchor.

SAM calculation applies conservative sector overlap percentages, actual serviceable market may be larger.

SOM uses 1-3% capture range derived from comparable API middleware categories.

Bottoms-up cross-check uses unit economics from Section 12.6 revenue table.

All figures should be treated as directional estimates subject to significant variance.

Independent market analysis recommended before investor presentation.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

13. Threat Model

Threat	Mitigation	Residual Risk
Confused deputy attack	CT scope enforced at every hop by TBAC engine	Negligible — cryptographic enforcement
Identity correlation	zkDID + stealth CT addresses + tx nonce	Negligible — unlinkable by construction
PII exposure at verifier	ZK proofs replace data transfer entirely	None — verifier receives no PII
Account takeover	Biometric binding + liveness on certified hardware	Low — requires defeating secure enclave
Sybil attacks	Nullifier registry enforced at enrollment	Low — requires biometric theft + enrollment device
Privilege escalation in agent chain	Scope invariants enforced at issuance	Negligible — child CT cannot exceed parent
Stale compliance proof	Policy NFT max proof age; oracle timestamps	Managed — proofs expire on schedule
Delegation depth abuse	maxDepth encoded in CT, enforced at issuance	Negligible — depth ceiling cryptographic
Txn-Token forgery	Immutable signed chain; workload identity bound	Low — requires signing key compromise
ZK circuit vulnerability	Audited Noir circuits; upgrade path defined	Managed — requires circuit-level audit
Enrollment coercion	Technical mitigations: liveness, supervised re-enrollment	Residual — procedural mitigations required
Issuer compromise	Multi-issuer attestation; geographic distribution	Managed — governance framework dependent
Trust Registry attack	On-chain immutability; governance quorum required	Managed — quorum key distribution critical

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

14. Implementation Pathway

14.1 Technology Stack

Layer	Component	EVM (Primary)	Cardano / XDC
ZK Proofs	Circuit design + proving	Noir (Aztec) + Barretenberg	Midnight native / Noir (XDC)
Smart Contracts	Token + policy contracts	Solidity 0.8.x	Plutus (Cardano) / Solidity (XDC)
DID / SSI	Identity management	Veramo + did:ethr	Atala PRISM (Cardano)
Biometric	Fuzzy extractor	IronMask + custom ZK circuit	Same across chains
Secure Enclave	Hardware attestation	Apple CryptoKit / Android StrongBox	Same across chains
Chain	Deployment target	Polygon Amoy → mainnet	XDC testnet / Midnight testnet / Hedera testnet
Hedera services	HTS + HCS	N/A primary	N/A primary
Token Standard	CAT / PNFT / CT	ERC-721 + ERC-1155	Cardano native / XRC-721
Oracle	Committed attribute state	Chainlink DECO / Merkle oracle	Same concept, chain-specific
Account Abstraction	CT UX	ERC-4337	N/A
KYC Bridge	VC issuance	Sumsub / Onfido SDK + VC adapter	Same
Backend	PDP + issuance service	NestJS + TypeScript	Same
Frontend	Demo + wallet	React + wagmi/viem	Same

Token Format Support: JWT/SD-JWT (primary, IETF-compliant), Biscuit (cryptographic attenuation for deep delegation), CWT/COSE (binary format for high-throughput agent-to-agent channels). See Section 7.4 for the complete token format selection mapping.

14.2 Phased Build

Phase 1 — Core Primitives (Months 1-3)

- TBAC enforcement engine in TypeScript (standalone, chain-independent)
- ABAC PDP service in NestJS — CT issuance as signed JWTs
- PolicyNFT.sol, CapabilityToken.sol, TrustRegistry.sol on EVM testnet

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

- CT delegation service with scope invariant enforcement
- React demo: ABAC evaluation → CT issuance → TBAC enforcement → delegation
- SPT-Txn interceptor for NestJS service chain

Phase 2 — ZK and Biometric (Months 3-6)

- Noir circuits for Attribute Proof (Circuit 1) and Compliance Claims (Circuit 2)
- On-chain verifier contracts generated from Noir circuits
- NullifierRegistry.sol and biometric enrollment contract
- iOS secure enclave integration (Swift + CryptoKit)
- Biometric Commitment Circuit (Circuit 3)

Phase 3 — SPT-Txn + Cross-Org (Months 6-9)

- Full SPT-Txn token implementation extending IETF base
- Cross-organizational CT verification via Trust Registry
- Privacy-preserving identity propagation (humanAnchor replaces sub)
- AI agent authorization SDK alpha
- KYC provider VC adapter (initial: one major provider)

Phase 4 — Multi-Chain (Months 9-15)

- XDC deployment (EVM-compatible — zero contract rewrite)
- Hedera deployment: HTS tokens + HCS audit trail + HEVM contracts
- Apply for HBAR Foundation grant (identity / enterprise track)
- Midnight prototype when testnet stabilizes
- Substrate parachain proof-of-concept
- PNFT composition for multi-jurisdictional compliance
- Mainnet deployment (EVM + XDC)

Phase 5 — Commercial Infrastructure (Months 15-24)

- Policy NFT marketplace
- Multi-provider KYC integration
- Compliance-as-a-Service API
- IETF standards contribution
- Enterprise pilots on XDC with trade finance partners

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

15. Standards Positioning and Related Work

15.1 Relationship to Existing Standards

Standard	Relationship	SPT-Txn Extension
IETF draft-ietf-oauth-transaction-tokens	Direct extension	CT binding, ZK privacy, agentic depth, cross-org trust
OAuth 2.0 / RFC 6749	Complements	Attribute provenance, ZK privacy, delegation depth
W3C Verifiable Credentials	Input layer	CATs are VC-derived; on-chain policy execution added
W3C DID Core	Identity anchor	Extended with ZK commitment for unlinkability
NIST SP 800-207 Zero Trust	Aligned	Cryptographic capability enforcement added to ZTA
NIST SP 800-63-3	Complements IAL/AAL	Biometric fuzzy commitment maps to IAL3
FATF Travel Rule	Implementation path	ZK compliance propagation solves agentic Travel Rule
ISO 20022	Integration via XDC	SPT-Txn authorization metadata in ISO 20022 messages
OpenID FAPI 2.0	Complements	ZK privacy, agentic delegation, cross-jurisdictional policy

15.2 Competitive Differentiation

System	What It Does	What SPT-Txn Adds
Worldcoin	Biometric Sybil resistance	ABAC policies, KYC integration, regulatory composability, Txn-Tokens, TBAC
Polygon ID	ZK identity on EVM	Biometric uniqueness, TBAC delegation, Txn-Token chain integrity
Atala PRISM	DID/SSI on Cardano	ABAC policy evaluation, TBAC enforcement, Txn-Tokens, biometric Sybil resistance
Civic / Fractal	Portable KYC	ZK privacy, biometric, ABAC execution, agentic delegation
XDC (base chain)	RWA trade finance infrastructure	ZK compliance proofs, TBAC agent authorization, portable KYC
AWS Verified Permissions	Cloud-native ABAC (Cedar)	User-sovereign identity, ZK privacy, on-chain audit, TBAC, Txn-Tokens
OAuth 2.0	Token-based auth	Attribute provenance, ZK, biometric, delegation depth, cross-org chain

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

16. Formal Security Analysis

This section provides an informal security analysis of the SPT-Txn Framework's core cryptographic components. The goal is not to provide full cryptographic proofs, which require dedicated academic treatment and peer review, but to enumerate the security properties claimed by the framework, sketch the reduction arguments that would support them, and identify the assumptions on which security depends. This level of rigor is sufficient for implementation review by security engineers and for cryptographic audit scoping. Formal proofs under standard cryptographic assumptions are a planned deliverable of Phase 2.

16.1 Security Properties

The SPT-Txn Framework claims the following security properties. Each is defined precisely, then the informal reduction argument is provided.

Property	Definition	Reduction Argument	Assumption
CT Unforgeability	An adversary cannot produce a valid Capability Token without authorization from an issuer holding the Policy NFT private key.	CT is a JWT signed by the issuer. Forgery requires breaking the issuer's signature scheme. Reduction: any CT forgery algorithm yields a signing oracle break.	EUF-CMA security of ECDSA/EdDSA (standard assumption).
ZK Soundness (Attribute Proofs)	A party cannot convince the PDP that it satisfies an attribute it does not hold.	ZK circuit soundness follows from the underlying proof system (Groth16 or PLONK). Any prover for a false statement yields a polynomial-time algorithm for the QAP satisfiability problem.	Computational soundness of Groth16 (KoE assumption in bilinear groups). Standard in the SNARK literature.
ZK Zero-Knowledge (Attribute Proofs)	The proof reveals nothing about the prover's attributes beyond what is encoded in the proof statement.	Follows from the simulator argument of Groth16. The simulator can produce a valid proof without witness access, so proofs carry no information beyond validity.	Existence of trusted setup or universal SRS (Groth16 requires per-circuit trusted setup).
Delegation Depth Integrity	An agent at depth d cannot issue a CT with depth greater than d−1, and cannot claim scope exceeding the parent CT scope.	Depth field is embedded in the CT and signed by issuer. Scope subset is enforced by the PDP at issuance. Any violation requires either CT forgery or PDP bypass.	CT Unforgeability + correct PDP implementation.
humanAnchor Integrity	Every SPT-Txn token's humanAnchor field correctly identifies the biometrically-verified human at the root of the delegation chain.	humanAnchor is set at CT issuance by a CAT-issuing authority and propagated immutably through delegation. Modification requires CT forgery at the root.	CT Unforgeability + CAT issuance integrity (KYC provider attestation).

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Property	Definition	Reduction Argument	Assumption
Biometric Unlinkability	Given two ZK biometric commitment proofs from the same individual, an adversary cannot link them to the same person without access to the biometric template.	The commitment binds a fuzzy extracted feature string to a random nonce. The nullifier prevents double-enrollment without revealing identity. Proof of same-origin requires inverting the commitment hash.	Collision resistance of SHA-256 + binding property of fuzzy commitment scheme (Dodis et al., 2004).
Nullifier Non-Reuse	A single biometric cannot generate two distinct nullifiers (preventing Sybil enrollment).	The nullifier is a deterministic function of the fuzzy-extracted biometric stable feature. Different individuals produce different feature strings with overwhelming probability. Same individual always produces same nullifier.	Injective property of fuzzy extractor stable component + collision resistance.

16.2 Trust Assumptions

The security of SPT-Txn rests on the following trust assumptions. Violations of these assumptions break specific properties as noted.

Assumption	What Breaks if Violated	Mitigation
Issuer Key Integrity — The CAT/CT issuer's private key is not compromised.	CT Unforgeability. A compromised issuer key enables arbitrary CT forgery.	Hardware HSM for issuer keys. Key ceremony documentation. Regular rotation.
Trusted Setup Soundness (Groth16) — The per-circuit trusted setup ceremony was not compromised.	ZK Soundness. A malicious setup participant who retains the toxic waste can generate false proofs.	Multi-party computation ceremony (Powers of Tau style). Audit of ceremony participants. Long-term: migrate to universal or transparent proof systems (PLONK/STARKs) that reduce or eliminate trusted setup requirements.
KYC Provider Attestation Integrity — KYC providers issue attestations only for verified individuals.	humanAnchor integrity. A corrupt KYC provider can issue CATs to unverified individuals.	Regulatory licensing of KYC providers. Multiple-provider corroboration for high-value CTs. On-chain revocation by governance when provider misconduct is detected.
Smart Contract Correctness — Policy NFT, Capability Token, and Nullifier Registry contracts behave as specified.	Depends on contract. Bug in Nullifier Registry could enable Sybil re-enrollment. Bug in Policy NFT could misconfigure compliance requirements.	Formal verification of smart contracts (Certora, Foundry invariant tests). Third-party audit (Trail of Bits, OpenZeppelin). Upgrade governance with time-lock.
Biometric Sensor Integrity — The enrollment device's biometric sensor accurately captures liveness and genuine features.	Biometric unlinkability and Sybil resistance. A spoofed biometric defeats the enrollment commitment.	ISO/IEC 30107 Presentation Attack Detection (PAD). Hardware attestation of enrollment device via secure enclave.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

16.3 Security Audit Roadmap

The following audit engagements are planned, ordered by implementation phase. Audit is not a substitute for secure design — it is a validation of secure design. The informal security analysis in this section provides the audit surface specification.

Phase	Audit Target	Firm (Target)	Scope
Phase 1 — Smart Contracts	PolicyNFT.sol, CapabilityToken.sol, TrustRegistry.sol, NullifierRegistry.sol	Trail of Bits or OpenZeppelin Audits	Functional correctness, access control, reentrancy, upgrade safety, storage layout
Phase 2 — ZK Circuits	Noir attribute proof circuits, compliance claim circuits, biometric commitment circuit	Trail of Bits or Veridise	Constraint completeness, soundness gap analysis, trusted setup ceremony design
Phase 2 — Biometric Module	Secure enclave integration, fuzzy extractor implementation, nullifier derivation	Specialized biometric security firm	Template leakage, nullifier collision probability, presentation attack resistance
Phase 3 — Protocol	End-to-end SPT-Txn delegation chain, CT delegation service, ABAC PDP	Kudelski Security or NCC Group	Protocol logic, delegation depth enforcement, scope subset invariant, replay protection
Phase 4 — Cryptographic Proofs	Formal reductions for claims in Section 16.1	Academic collaboration (TBD)	Full game-based proofs under standard cryptographic assumptions

Note on Formal Proofs

The informal reduction arguments in Section 16.1 are not security proofs.
They identify the structure a formal proof would take and the assumptions it would require.
Formal cryptographic proofs are a planned deliverable following the Phase 2 ZK circuit audit.
Independent cryptographic review should be commissioned before any production deployment.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

17. Post-Quantum Cryptography Considerations

Current primitives (ECDSA-P256, Groth16, Pedersen commitments) are vulnerable to harvest-now-decrypt-later attacks on permanent on-chain state (nullifier registry, Trust Registry). ENISA Threat Landscape 2025

Migration path:

- Signatures → ML-DSA (FIPS 204)
- Key encapsulation → ML-KEM (FIPS 203)
- ZK proofs → STARKs or lattice-based SNARKs

ENISA Threat Landscape 2025, NIST CSWP 48 (2025), and Global Risk Institute

Quantum Threat Timeline Report 2025 identify 2030–2035 as the critical window. SPT-Txn's modular crypto layer supports phased replacement without protocol redesign.

In Cayman fintech deployments, we already treat ECDSA keys as transitional. Operators should plan ML-KEM / ML-DSA migration now-SPT-Tn's modular cryptolayer makes this feasible without protocol rewrite.

17.1 Cryptographic Dependency Inventory

Component	Cryptographic Primitive	Quantum Vulnerability Class	Quantum Attack
ZK attribute proofs (Groth16)	ECC BN254 pairing	VULNERABLE	Shor's algorithm breaks discrete log — ZK soundness collapses
CT token signatures (JWT/SD-JWT, Biscuit, CWT)	ECDSA P-256/secp256k1 (JWT, SD-JWT, CWT); Ed25519 (Biscuit block signatures)	VULNERABLE	Shor's algorithm recovers signing key from public key
zkDID key pairs	ECDSA or EdDSA	VULNERABLE	Same as JWT signatures
Blockchain transaction signatures	ECDSA secp256k1 (EVM, Hedera, XDC), Ed25519 (Cardano)	VULNERABLE	Same as above — ecosystem-level problem, not SPT-Txn specific
Biometric fuzzy commitment	SHA-256 / SHA-3 hash functions	WEAKENED (not broken)	Grover's algorithm halves effective security: 256→128 bits — manageable with SHA-512
Nullifier registry hashes	SHA-256 / SHA-3	WEAKENED (not broken)	Same as biometric commitment

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Component	Cryptographic Primitive	Quantum Vulnerability Class	Quantum Attack
HCS audit trail (Hedera)	SHA-384 internally	WEAKENED (not broken)	Adequate with Hedera's current hash choice — Hedera is responsible for migration

17.2 Threat Timeline and Harvest-Now-Decrypt-Later

The largest quantum computers in operation as of 2026 comprise approximately 1,000-2,000 physical qubits. The error correction overhead at current fidelity rates is approximately 1,000 physical qubits per logical qubit, yielding approximately 1-2 logical qubits available for computation. Breaking ECC-256 using Shor's algorithm requires approximately 2,000-3,000 logical qubits. The gap is three orders of magnitude.

Credible expert estimates for cryptographically-relevant quantum computing: NIST and ENISA place the timeline at 10-20 years; more optimistic industry projections suggest 5-10 years. No credible expert claims a breakthrough in under five years. This framework's planning horizon assumes a 10-15 year window before quantum-vulnerable primitives must be fully replaced.

The Harvest-Now-Decrypt-Later Distinction

Not all SPT-Txn data has equal quantum exposure:

SHORT-LIVED DATA — LOW RISK:
Capability Tokens and SPT-Txn tokens are valid for minutes to hours.
A quantum adversary harvesting CT signatures today gains nothing, the tokens are expired.
Harvest-now-decrypt-later threat to short-lived tokens: negligible.

PERMANENT ON-CHAIN DATA — REAL RISK:
Nullifier registry entries are on-chain forever by design.
Trust Registry state is permanent.
Policy NFT issuance records are immutable.
HCS audit trail is immutable.
An adversary who harvests these on-chain signatures today and breaks ECC in 15 years can retroactively forge the appearance of valid authorization events.

This distinction drives the migration priority: permanent on-chain state has higher urgency than runtime token signatures.

17.3 NIST Post-Quantum Standards — Applicability to SPT-Txn

NIST finalized four post-quantum cryptography standards in August 2024. Three are immediately applicable to SPT-Txn components.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

NIST Standard	Primitive	Replaces	SPT-Txn Applicability	Migration Difficulty
FIPS 204 — ML-DSA (CRYSTALS-Dilithium)	Lattice-based digital signature (MLWE)	ECDSA, EdDSA	CT/CAT JWT signatures, zkDID key pairs, Trust Registry signatures	LOW — drop-in via new JWT 'alg' header; JOSE WG defining algorithm identifiers
FIPS 205 — SLH-DSA (SPHINCS+)	Stateless hash-based signature	ECDSA for signing	Signing operations where signature size is acceptable	LOW-MEDIUM — signatures 8-50KB vs 64 bytes ECDSA; suitable for infrequent operations
FIPS 203 — ML-KEM (CRYSTALS-Kyber)	Key encapsulation (MLWE)	ECDH key exchange	Not directly applicable to current SPT-Txn design; relevant for secure channel establishment	N/A (future)
FN-DSA (FALCON) — Draft	Compact lattice-based signature (NTRU)	ECDSA	Same as ML-DSA; smaller signatures (~666 bytes vs ~2.4KB Dilithium)	LOW — pending final NIST publication

17.4 The ZK Circuit Challenge

The most technically complex quantum migration challenge in SPT-Txn is the ZK proof system. The current implementation targets Noir/Barretenberg with Groth16 as the primary backend. Groth16 depends on the hardness of the elliptic curve discrete logarithm problem in BN254 pairing groups, directly broken by Shor's algorithm.

ZK System	Quantum Resistance	Status	Proof Size	Verification Cost	Trade-off
Groth16 (Noir current)	VULNERABLE (ECC-based)	Production-ready	~200 bytes	~2ms on-chain	Best performance; not quantum-safe
PLONK (Noir alternative)	VULNERABLE (ECC-based)	Production-ready	~400-800 bytes	~5ms on-chain	Better developer experience; same quantum exposure
STARKs (StarkWare, Polygon zkEVM)	RESISTANT (hash-based SHA/Poseidon)	Production-ready	40-100KB	~10-50ms on-chain	200-500x larger proofs; no trusted setup; quantum-safe
Lattice ZK (MLWE-based)	RESISTANT	Research/early stage	Impractical for on-chain	Impractical	Not viable for production deployment yet

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

ZK System	Quantum Resistance	Status	Proof Size	Verification Cost	Trade-off
Hash-based ZK (MPC-in-the-head)	RESISTANT	Research stage	Very large	Impractical	Not viable for on-chain verification currently

The practical conclusion: STARKs are the only production-ready, quantum-resistant ZK system available today. The trade-off is proof size, STARKs produce proofs 200-500 times larger than Groth16. For on-chain verification this increases gas costs proportionally. For use cases where proof size is not the primary constraint (audit anchoring to HCS, off-chain verification), STARK-based proofs are viable now.

17.5 Migration Roadmap

Phase	Timeline	Action	Priority Driver
Phase 1 (Now — PoC)	2026	Implement current design with Groth16 and ECDSA. Document quantum exposure explicitly. Scope audit to include post-quantum migration surface.	10-15 year threat horizon makes current implementation acceptable for prototype and early commercial deployment.
Phase 2 (2027)	2027	Migrate CT/CAT JWT signatures to ML-DSA (FIPS 204) for all new issuances. Update zkDID key pair generation to use ML-DSA or SLH-DSA. Evaluate FALCON for compact signatures.	Permanent on-chain signatures created during Phase 2 deployments will exist indefinitely — earlier migration reduces long-term exposure.
Phase 3 (2027-2028)	2027-2028	Pilot STARK-based ZK proof system for compliance claim proofs. Benchmark proof sizes and verification costs on target chains (HEVM, EVM, XDC). Evaluate feasibility of STARK migration for attribute proofs.	STARKs are production-ready. Pilot data from Phase 3 informs the Phase 4 migration decision.
Phase 4 (2028-2029)	2028-2029	Full ZK migration to STARK-based backend for all proof types where on-chain verification costs are acceptable. Maintain Groth16 for use cases with strict size constraints pending further STARK optimization.	ZK soundness is the highest-value security property — it is what makes the compliance proof trustworthy.
Phase 5 (2029+)	2029+	Ecosystem dependency resolution — blockchain platforms must implement native PQC transaction signatures. Monitor NIST and EVM	Blockchain-level PQC is an ecosystem problem. SPT-Txn's contracts can be upgraded; the underlying chain signatures

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Phase	Timeline	Action	Priority Driver
		roadmaps. Participate in standards discussions. Maintain upgrade governance for smart contracts.	cannot be changed by SPT-Txn alone.

PQC Summary

SPT-Txn is not currently quantum-resistant. This is an honest statement, not a weakness.
Token-level signatures (short-lived) have low quantum urgency.
Permanent on-chain state has higher urgency, ML-DSA migration should begin in Phase 2.
ZK circuit migration to STARKs is technically feasible, the trade-off is proof size.
A 10-15 year threat window provides adequate time for a structured, phased migration.
No production financial system claims quantum resistance today, SPT-Txn's honesty and structured migration roadmap are strengths relative to systems that ignore the question.

18. Experimental Evaluation (Preliminary – POC Pending)

These are initial simulated results utilizing (Noir/Barretenberg v0.30+, Node.js 20, M1 Max, March 2026) for TBAC enforcement. Full audited PoC benchmarks will appear in v7.0 with hardware details, methodology, and reproducibility scripts.

Operation	Environment	Result	Notes
TBAC Enforcement (8 steps)	Node.js, in-memory	1.4 ms	10,000 runs, no revocation check
TBAC Enforcement (8 steps)	Node.js, in-memory	0.8 ms	10,000 runs, with local revocation cache
TBAC Enforcement (8 steps)	Node.js, in-memory	< 2 ms	Offline mode (no network)
ZK Proof Generation (Circuit 1)	Attribute proof, standard laptop	~720 ms	standard laptop
ZK Proof Generation (Circuit 2)	Compliance claim proof, standard laptop	~850 ms	standard laptop
ZK Proof Generation (Circuit 3)	Biometric commitment proof, standard laptop	~1,100 ms	includes fuzzy extractor
ZK Proof Verification (Groth16)	Groth16 verification on-chain (Solidity)	240,000 gas (~$0.018)	March 2026 Polygon rates

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Operation	Environment	Result	Notes
On-chain Verification	Polygon Amoy testnet CAT mint (ERC-721)	140,000 gas (~$0.008)	March 2026 gas rates
On-chain Verification	Polygon Amoy testnet PNFT deployment	480,000 gas (~$0.03)	March 2026 gas rates
On-chain Verification	Polygon Amoy testnet CT issuance (ERC-1155)	75,000 gas (~$0.004)	March 2026 gas rates
Hedera HCS Anchoring	Hedera testnet	~$0.0001 / message	3–5 s absolute finality

Full audited PoC benchmarks and methodology will be included in v7.0.

The initial results above are consistent with published proving times for comparable Noir/Barretenberg circuits and are expected to improve with hardware acceleration and circuit optimisation. Each measurement category in Sections 18.1–18.4 defines a stated target representing the threshold for practical deployment in regulated financial services. Reproducibility: TBAC mock code and Noir circuit skeletons are available on request; the full repository is planned for release post-Phase 1 PoC.

18.1 TBAC Enforcement Engine — Latency

The eight-step TBAC enforcement sequence (Section 4) operates solely on the Capability Token and should require no external calls in the common case. Target metrics:

Measurement	Target	Rationale
Single CT verification (in-process)	< 5ms p99	Enforcement must not introduce perceptible latency in API call chain
CT verification under 10,000 concurrent requests	< 20ms p99	Target throughput for financial services API gateway
Revocation check (on-chain, HCS)	< 100ms p99	HCS finality 3-5 seconds; revocation check is async and pre-fetched
Full ABAC evaluation at CT issuance	< 500ms p99	CT issuance is a control-plane operation; latency tolerance is higher

18.2 ZK Proof Generation and Verification

Circuit	Proof System	Target Generation Time	Target Verification Time	Target Proof Size
Attribute proof (3 attributes)	Groth16 (Noir/Barretenberg)	< 2 seconds	< 5ms	< 200 bytes

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Circuit	Proof System	Target Generation Time	Target Verification Time	Target Proof Size
Compliance claim proof	Groth16	< 3 seconds	< 5ms	< 256 bytes
Biometric commitment proof	Groth16	< 5 seconds	< 10ms	< 512 bytes
Combined proof (attribute + compliance)	Groth16 recursive	< 8 seconds	< 10ms	< 400 bytes
STARK baseline comparison	STARK (benchmark)	< 30 seconds	< 50ms on-chain	40-100KB

18.3 On-Chain Gas Costs (EVM / Polygon)

Operation	Target Gas	Target USD Cost (2026 Polygon Amoy rates)	Notes
CAT issuance (ERC-721 mint)	< 150,000 gas	< $0.01	One-time per user enrollment
Capability Token issuance (ERC-1155)	< 80,000 gas	< $0.005	Per CT issuance
Nullifier registration	< 60,000 gas	< $0.003	Per biometric enrollment
ZK proof verification (Groth16)	< 250,000 gas	< $0.02	Per compliance verification
Policy NFT deployment	< 500,000 gas	< $0.05	One-time per jurisdiction/issuer
HCS message (Hedera)	Fixed ~0.0001 USD	~$0.0001	Predictable operational cost

18.4 System Throughput

Target throughput for Phase 1 PoC on single-region NestJS deployment with Polygon Amoy testnet:

Scenario	Target TPS	Notes
CT verification (TBAC, in-process)	10,000 TPS	Stateless verification; horizontally scalable
CT issuance (ABAC evaluation)	500 TPS	Policy evaluation overhead; scales with PDP compute
ZK proof generation (off-chain)	10 proofs/second	GPU-accelerated; parallelizable
On-chain operations (EVM)	50-100 TPS	Limited by block gas limit and finality; Hedera achieves 10,000+ TPS

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

These targets will be revised following PoC implementation. The section will be updated with empirical results, methodology, hardware configuration, and reproducibility instructions in v7.0.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

19. Legal and Regulatory Considerations

Legal Counsel Required

This section provides substantive analysis of legal and regulatory frameworks relevant to SPT-Txn operators.
It is not legal advice. The analysis reflects the author's understanding of applicable frameworks as of March 2026 and may not reflect subsequent regulatory developments.
Operators must engage qualified legal counsel before any production deployment.
Regulatory requirements vary by jurisdiction, entity type, and specific use case.

The SPT-Txn Framework operates at the intersection of identity law, data protection regulation, financial services licensing, AI governance requirements, and blockchain regulatory frameworks. Operators building on SPT-Txn infrastructure must navigate each applicable framework independently. This section surveys the primary applicable regulatory regimes and their implications for SPT-Txn deployments.

From my Cyber Security background in regulated environments, operators should treat SPT-Txn as infrastructure, not a licensed activity. In Violet Sky Security SEZC (Cayman Islands), this structure benefits from the jurisdiction's fintech sandbox and clear VASP rules under the VASP Act 2020. Engage counsel early to map CT issuance to any potential CASP triggers under VARA or MiCA or FinSec.

19.1 GDPR and Data Protection

The General Data Protection Regulation (EU) 2016/679 imposes substantive obligations on any entity processing personal data of EU data subjects. Several SPT-Txn design choices are directly motivated by GDPR compliance requirements.

ZK proofs and commitments satisfy data minimisation (Art. 5(1)(c)). On-chain nullifiers do not constitute personal data under most DPA guidance. Controller-processor agreements required for multi-party deployments.

GDPR Principle	SPT-Txn Design Response	Residual Compliance Question
Data Minimisation (Art. 5(1)(c)) — collect only what is necessary	ZK proofs reveal only the claim being proven (age > 18, jurisdiction = EU) without transmitting underlying PII. No document sharing.	ZK proof verifier must not log proof inputs that could reconstruct attributes.
Purpose Limitation (Art. 5(1)(b)) — use data only for stated purpose	Capability Token scope field cryptographically limits what the CT can be used for. Out-of-scope use fails at enforcement.	CT scope specification must be specific and documented at issuance; broad scope CTs may raise purpose limitation questions.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

GDPR Principle	SPT-Txn Design Response	Residual Compliance Question
Right to Erasure (Art. 17) — data subjects can request deletion	ZK proofs do not store PII on-chain. Biometric data is held off-chain by the enrollment service. On-chain nullifier is a hash commitment — not personal data under CJEU guidance.	Regulators in some jurisdictions have contested whether blockchain commitments constitute personal data. Legal analysis required per deployment.
Data Controller / Processor Liability (Art. 24, 28)	Issuing authority is data controller. KYC providers are data processors. SPT-Txn protocol is infrastructure, not a data controller per se.	Multi-party deployments with multiple issuers require clear controller/processor agreements. Template available from EU authorities.
International Transfers (Art. 46)	On-chain data is accessible globally by design. If ZK proofs or commitment hashes constitute personal data, international transfer rules apply.	Adequacy decisions, SCCs, or BCRs required for transfers to non-adequate countries. Critical legal analysis for cross-jurisdictional deployments.

The CJEU has not issued a definitive ruling on whether cryptographic commitments on public blockchains constitute personal data under GDPR. The Belgian DPA (2023) and the French CNIL have issued guidance suggesting that commitments from which the underlying data cannot be recovered (even with significant effort) may fall outside the GDPR definition of personal data. The Italian Garante and the Spanish AEPD have taken more cautious positions. Operators must seek jurisdiction-specific legal advice.

19.2 EU AI Act — Article 14 Obligations

Regulation (EU) 2024/1689 (EU AI Act) entered into force August 1, 2024, with full application from August 2, 2026. Article 14 imposes mandatory human oversight requirements on high-risk AI systems. SPT-Txn is positioned as the technical mechanism that enables demonstrable compliance with Article 14 for AI agents operating in regulated financial services.

Article 14 Requirement	SPT-Txn Technical Implementation	Evidence for Compliance
Art. 14(1) — Effective human oversight by design	humanAnchor field in every CT and SPT-Txn token cryptographically links every agent action to the human who authorized it.	CT issuance records on HCS provide tamper-evident evidence of human authorization at root of every chain.
Art. 14(4)(a) — Understand system capacities and limitations	CT scope field explicitly specifies what the agent is authorized to do. Scope is cryptographically enforced — agent cannot exceed stated scope.	CT scope specification serves as the formal statement of agent capacities presented to human overseers.
Art. 14(4)(b) — Monitor system operation	HCS audit trail provides real-time, immutable record of every CT	HCS topic stream provides monitoring feed for human oversight dashboards.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Article 14 Requirement	SPT-Txn Technical Implementation	Evidence for Compliance
	issuance, delegation hop, and revocation event.	
Art. 14(4)(d) — Able to intervene and stop system	CT revocation at protocol level (HTS wipe, or on-chain revocation registry) enables immediate human override of any agent authorization.	Revocation event recorded on HCS with timestamp provides evidence of human override capability.
Art. 14(4)(e) — Able to override outputs	Delegation depth counter limits how far an agentic chain can extend without human re-authorization.	Depth-zero CTs require direct human action — structural limit on agentic autonomy without human re-engagement.

The penalty for non-compliance with Article 14 obligations for high-risk AI systems is up to EUR 30 million or 6% of total worldwide annual turnover (whichever is higher) under Article 99. For AI companies with significant revenue, this is a material compliance requirement. SPT-Txn provides the technical substrate for Article 14 compliance, operators must also implement the governance framework, documentation, and incident response procedures required under Articles 9, 17, and 61.

19.3 FATF Travel Rule

FATF Recommendation 16 (the 'Travel Rule') requires Virtual Asset Service Providers (VASPs) to obtain, hold, and transmit originator and beneficiary information for virtual asset transfers. The threshold is USD 1,000 (or equivalent) under FATF guidance, though jurisdictions may set lower thresholds (the EU's Transfer of Funds Regulation sets EUR 0).

Travel Rule Obligation	SPT-Txn Mechanism	Jurisdictional Variance
Originator identification	humanAnchor field in SPT-Txn token identifies the biometrically-verified human originator. KYC provider holds originator PII available for lawful VASP-to-VASP exchange.	All major jurisdictions require originator name, account number, and transaction details. EU TFR requires EUR 0 threshold.
Beneficiary identification	SPT-Txn does not address beneficiary identification — this remains a bilateral VASP protocol obligation using existing messaging solutions (TRISA, OpenVASP, Sygna).	Beneficiary identification is separate from originator chain of custody and requires independent solution.
Agentic transaction chains	humanAnchor propagation through delegation hops preserves originator identity across multi-hop agent transactions. Each hop records CT reference in spt_compliance_ref.	No jurisdiction has yet issued guidance specifically addressing agentic Travel Rule compliance. FATF VASP Guidance (2021)

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Travel Rule Obligation	SPT-Txn Mechanism	Jurisdictional Variance
		predates widespread agentic AI deployment.
Record retention	HCS audit trail provides tamper-evident, timestamped record of every transaction in the SPT-Txn chain, satisfying record retention obligations.	Most jurisdictions require 5-year retention. HCS is permanent and immutable — retention is structurally guaranteed.

19.4 Markets in Crypto-Assets Regulation (MiCA)

Regulation (EU) 2023/1114 (MiCA) established the first comprehensive EU framework for crypto-asset services. MiCA applies to CASPs (Crypto-Asset Service Providers) operating in the EU and imposes authorization, governance, and consumer protection requirements. MiCA is now in full application.

For SPT-Txn deployments in EU-regulated contexts: Policy NFTs encoding MiCA compliance requirements enable CASPs to programmatically verify investor eligibility, jurisdictional compliance, and AML status. The compliance proof carried in an SPT-Txn token, including spt_compliance_ref with ZK-attested MiCA eligibility, satisfies CASPs' know-your-customer obligations when the underlying ZK attestation comes from a licensed, MiCA-authorized KYC provider. CASPs must ensure the KYC provider holding the attestation source data is itself authorized under applicable AML directives.

19.5 Virtual Assets Regulatory Authority (VARA)

Dubai's VARA established the world's first purpose-built virtual asset regulatory framework through its Virtual Asset Rulebook (2023) and subsequent activity-specific regulations. VARA regulates Virtual Asset Service Providers operating in or from Dubai's Mainland and DIFC (Dubai International Financial Centre, which operates its own parallel framework through DFSA).

For SPT-Txn deployments in VARA-regulated contexts: VARA requires CASPs to implement robust KYC, AML, and transaction monitoring programs. Policy NFTs encoding VARA-specific eligibility requirements, including VARA-licensed counterparty requirements, permissible asset types, and investor category thresholds, enable platforms to automate compliance with VARA's technical requirements. The humanAnchor and delegation audit trail directly satisfy VARA's requirements for transaction monitoring and suspicious transaction reporting.

19.6 Smart Contract and Blockchain Legal Status

The legal status of smart contracts, NFTs, and blockchain records varies significantly across jurisdictions and remains an area of active legislative development.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

Jurisdiction	Smart Contract Legal Status	NFT Legal Status	Blockchain Record Admissibility
European Union	No EU-wide smart contract legal recognition framework. Member state contract law applies. MiCA and DORA impose operational requirements on DLT use.	MiCA classifies some NFTs as crypto-assets subject to regulation depending on transferability and fungibility.	Admissible as electronic records under eIDAS Regulation (EU) 910/2014 when appropriately authenticated.
United Kingdom	Law Commission confirmed smart contracts can constitute binding legal contracts (2021) where offer, acceptance, consideration present.	No specific NFT legislation; property law principles apply.	Admissible under Civil Evidence Act 1968 with appropriate authentication.
United States	State-level variation. Wyoming, Arkansas, Tennessee have enacted smart contract enforceability statutes. UETA / E-SIGN cover digital contracts generally.	SEC treatment of NFTs as securities (depending on economic reality) remains unsettled.	Admissible under Federal Rules of Evidence 803(6) (business records exception) with proper foundation.
Cayman Islands	No specific legislation. English contract law principles apply. Smart contracts enforceable as contracts where common law elements satisfied.	No specific framework. General property law applies.	Admissible as electronic records with appropriate authentication.
United Arab Emirates	DIFC Law No. 2 of 2017 recognizes electronic contracts. ADGM Electronic Commerce Regulations recognize smart contracts.	VARA Virtual Asset Rulebook addresses NFTs as a category of virtual asset.	Admissible under UAE Federal Law No. 1 of 2006 on Electronic Commerce.

Operator Legal Checklist

Before deploying SPT-Txn infrastructure in production, operators should address:

1. GDPR / Data Protection: Appoint Data Protection Officer if required. Conduct DPIA. Determine whether on-chain commitments constitute personal data in target jurisdictions. Establish controller/processor agreements with KYC providers.

2. Financial Services Licensing: Determine whether CT issuance or KYC attestation constitutes a licensable activity in target jurisdictions. Engage regulatory counsel.

3. AML / Travel Rule: Implement VASP-to-VASP messaging protocol for Travel Rule compliance. Register with FIU if required. Establish transaction monitoring program.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

4. EU AI Act: Conduct AI risk classification assessment. Implement Article 9 risk management system. Document Article 14 human oversight mechanisms.

5. Smart Contract Legal Review: Engage technology law counsel to assess enforceability of on-chain Policy NFTs and Capability Tokens under applicable contract law.

This checklist is not exhaustive. Regulatory requirements evolve rapidly.
Continuous monitoring and qualified legal advice are essential.

20. Conclusion

The SPT-Txn Framework v6.0 resolves the authorization gap at the intersection of three converging demands: regulated digital economies requiring compliance-provable identity at machine speed, AI agents requiring scoped and cryptographically accountable authorization, and multi-chain financial infrastructure requiring cross-jurisdictional policy composability.

The two-phase evaluation model places ABAC where it belongs, at token issuance, and TBAC where it belongs, at every access event. The result is fine-grained policy expressiveness without per-access-event evaluation overhead. The eight-step TBAC Enforcement Engine provides a formally specified, offline-capable, millisecond-latency enforcement component whose correct behavior is provable from the token alone.

The ZK circuit architecture (Section 5) provides formal proof statements for attribute proofs, compliance claims, and biometric commitments, sufficient for cryptographic review and implementation. The biometric enrollment contract architecture (Section 6) specifies a complete on-chain/off-chain security boundary for Sybil-resistant enrollment without biometric data custody. The multi-chain deployment architecture (Section 11) addresses four distinct deployment contexts with implementations aligned to each chain's strengths.

The IETF Transaction Token extension (draft-coetzee-oauth-spt-txn-tokens-03) provides a standards-body engagement path. The companion document is submitted to the IETF OAuth Working Group as an informational draft.

Future Work

v7.0 will incorporate full PoC benchmarks, audited Noir circuits, real-world pilot results (target: VARA-regulated exchange), and STARK migration paths for quantum hardening. I also plan deeper integration examples with Hedera HTS/HCS and Midnight ZK runtime. Community feedback on the IETF draft will drive refinements.

Contact and Engagement

The author welcomes engagement from researchers, standards bodies, regulated entities, KYC providers, AI companies, and investors.

Topics: implementation collaboration, commercial licensing, advisory engagement,

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

IETF co-authorship, academic collaboration, pilot partnerships.

Violet Sky Security LLC (US) • Violet Sky Security SEZC (Cayman Islands)

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

References

1. Tschofenig, H., Brandner, A., Nadalin, A. (2024). Transaction Tokens. IETF draft-ietf-oauth-transaction-tokens. IETF.
2. Hardt, D. (2012). The OAuth 2.0 Authorization Framework. RFC 6749. IETF.
3. Jones, M., Bradley, J., & Sakimura, N. (2015). JSON Web Token (JWT) (RFC No. 7519). Internet Engineering Task Force. https://doi.org/10.17487/RFC7519
4. World Wide Web Consortium. (2022). Verifiable Credentials Data Model v1.1. W3C Recommendation.
5. World Wide Web Consortium. (2023). Decentralized Identifiers (DIDs) v1.0. W3C Recommendation.
6. Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture (NIST Special Publication 800-207). National Institute of Standards and Technology.
7. Grassi, P. A., Garcia, M. E., & Fenton, J. L. (2017). Digital identity guidelines (NIST Special Publication 800-63-3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-63-3.
8. Buterin, V. (2022). Decentralized Society: Finding Web3's Soul. Ethereum Foundation.
9. Hardy, N. (1988). The Confused Deputy. ACM SIGOPS Operating Systems Review.
10. Miller, M. (2006). Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control. PhD Thesis, Johns Hopkins University.
11. Dodis, Y., Reyzin, L., Smith, A. (2004). Fuzzy Extractors. EUROCRYPT 2004.
12. Groth, J. (2016). On the Size of Pairing-Based Non-interactive Arguments. EUROCRYPT 2016.
13. Zhang, F., Maram, S. K. D., Malvai, H., Goldfeder, S., & Juels, A. (2020). DECO: Liberating web data using decentralized oracles for TLS. In Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security (pp. 1919–1938). Association for Computing Machinery. https://doi.org/10.1145/3372297.3417239
14. FATF. (2021). Updated Guidance for Virtual Assets and Virtual Asset Service Providers.
15. European Union. (2023). Markets in Crypto-Assets Regulation (MiCA).
16. Virtual Assets Regulatory Authority. (2023). VARA Virtual Asset Rulebook. Dubai.
17. OpenID Foundation. (2023). Financial-grade API Security Profile 2.0 (FAPI 2.0).
18. Input Output Global. (2023). Atala PRISM: Decentralized Identity on Cardano. IOG Technical Report.
19. XDC Network. (2023). XDC Network Technical Whitepaper: Hybrid Blockchain for Trade Finance.
20. Hedera Hashgraph. (2023). Hedera: An Open, Sustainable, Enterprise-Grade Public Network. Hedera Technical Report.
21. Baird, L., Harmon, M., Madsen, P. (2016). Swirlds Hashgraph Consensus Algorithm: Fair, Fast, Byzantine Fault Tolerance. Swirlds Technical Report.
22. Aztec Network. (2024). Noir: A Domain-Specific Language for SNARK Proving Systems. Aztec Labs.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.

23. Parno, B., Howell, J., Gentry, C., & Raykova, M. (2013). Pinocchio: Nearly practical verifiable computation. In 2013 IEEE Symposium on Security and Privacy (pp. 238–252). IEEE. https://doi.org/10.1109/SP.2013.25
24. National Institute of Standards and Technology. (2024). FIPS 204: Module-Lattice-Based Digital Signature Standard (ML-DSA). NIST.
25. National Institute of Standards and Technology. (2024). FIPS 205: Stateless Hash-Based Digital Signature Standard (SLH-DSA). NIST.
26. National Institute of Standards and Technology. (2024). FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM). NIST.
27. European Parliament. (2024). Regulation (EU) 2024/1689 — EU Artificial Intelligence Act. Official Journal of the EU.
28. European Parliament. (2023). Regulation (EU) 2023/1114 — Markets in Crypto-Assets Regulation (MiCA). Official Journal of the EU.
29. European Parliament. (2016). Regulation (EU) 2016/679 — General Data Protection Regulation (GDPR). Official Journal of the EU.
30. Fenergo. (2025). Global KYC & AML Survey 2025. Fenergo Research Report.
31. BCG and Ripple. (2024). Approaching the Tokenization Tipping Point. Boston Consulting Group.
32. MarketsandMarkets. (2024). Identity Verification Market — Global Forecast 2030.
33. Mordor Intelligence. (2025). Agentic AI in Financial Services Market Report.
34. Gartner. (2026, February). AI Governance Market Forecast 2026-2030.
35. ENISA. (2025). Threat Landscape 2025.
36. NIST. (2025). CSWP 48: Post-Quantum Cryptography Migration Roadmap.
37. Global Risk Institute. (2025). Quantum Threat Timeline Report.
38. Coetzee, R.J. (2026). draft-coetzee-oauth-spt-txn-tokens-04: Capability-Scoped Transaction Tokens for Agentic Systems. IETF Internet-Draft.

© 2026 R.J. Coetzee — Violet Sky Security LLC / Violet Sky Security SEZC. All rights reserved.